

- **Expediente N.º: EXP202213537**

RESOLUCIÓN DE PROCEDIMIENTO SANCIONADOR

Del procedimiento instruido por la Agencia Española de Protección de Datos y en base a los siguientes

ANTECEDENTES

PRIMERO: En fecha 5 de octubre de 2022 y 4 de noviembre de 2022, se reciben dos notificaciones de brechas de seguridad por parte de MARKTEL GLOBAL SERVICES S.A (en lo sucesivo MARKEL) con número de registro de entrada REGAGE22e00044254458 y REGAGE22e00049917967.

Del contenido de ambas notificaciones se extrae la siguiente información relevante:

- Descripción de la brecha: “(...)”
(...)

SEGUNDO: En fechas 22 de octubre de 2022 y 21 de noviembre de 2022 se recibieron dos notificaciones de brecha por parte de ORANGE ESPAGNE SAU (en lo sucesivo ORANGE u ORANGE ESPAGNE), de su contenido se extrae la siguiente información:

- Descripción: “(...)”.

TERCERO: En fecha 28 de octubre de 2022 y registro de entrada REGAGE22e00048666972 se recibió notificación de brecha de seguridad por parte del responsable de tratamiento ORANGE BANK SA (SUCURSAL EN ESPAÑA) (en lo sucesivo, ORANGE BANK) con la siguiente información destacada:

- Descripción: “(...)”.

CUARTO: En fecha 18 de noviembre de 2022, **D. A.A.A.** (en adelante, la parte reclamante uno) interpuso reclamación ante la Agencia Española de Protección de Datos. La reclamación se dirige contra ORANGE ESPAGNE y MARKTEL.

Los motivos en que basa la reclamación son los siguientes:

“El reclamante es un cliente de JAZZTEL al que la operadora comunicó que sus datos personales (...) pudieron haberse visto expuestos como consecuencia de un incidente de seguridad que afectó a un proveedor de la compañía. El afectado solicitó que se le concretaran los datos expuestos, recibiendo como respuesta todos los datos enumerados anteriormente, a excepción (...)”

Fecha en la que tuvieron lugar los hechos reclamados: 11 de noviembre de 2022.

Documentación relevante aportada por la parte reclamante:

- Se adjunta captura de pantalla del correo recibido por parte de JAZZTEL comunicando la violación de seguridad e informando sobre la afectación de sus datos personales, este correo tiene fecha de 11 de noviembre de 2022.
- Se adjunta captura de pantalla de la respuesta que da el usuario a JAZZTEL tras la recepción del correo anterior, solicitando más información sobre el incidente de seguridad y la afectación de sus datos personales.
- Se adjunta captura de pantalla de la respuesta que da JAZZTEL al correo anterior enviado por el usuario, ofreciendo al reclamante más detalles sobre la brecha. Este correo tiene fecha de 17 de noviembre de 2022.

QUINTO: En fecha 9 de diciembre de 2022, D. **B.B.B.** (en adelante, la parte reclamante dos), interpuso reclamación ante la Agencia Española de Protección de Datos. La reclamación se dirige contra ORANGE. y MARKTEL.

Los motivos en que basa la reclamación son los siguientes:

“El reclamante es un cliente de ORANGE al que la operadora comunicó que sus datos personales (...) pudieron haberse visto expuestos como consecuencia de un incidente de seguridad que afectó a un proveedor de la compañía”.

Fecha en la que tuvieron lugar los hechos reclamados: 9 de diciembre de 2022.

Documentación relevante aportada por la parte reclamante:

Se adjuntan capturas de pantalla de los correos recibidos por parte de ORANGE comunicando la filtración de sus datos personales. El contenido de este correo electrónico lleva la firma tanto del DPD de ORANGE como de ORANGE BANK, en el contenido se hace referencia a que ambas entidades actúan como responsables de tratamiento, al ser ORANGE BANK responsable de la financiación de los dispositivos adquiridos por el cliente cuyos datos personales se han visto afectados.

SEXTO: De conformidad con el artículo 65.4 de la Ley Orgánica 3/2018, de 5 de diciembre, de Protección de Datos Personales y Garantía de los Derechos Digitales (en adelante LOPDGDD), en fecha 23 de diciembre de 2022, se dio traslado de dichas reclamaciones a ORANGE ESPAGNE y a MARKTEL, para que procediesen a su análisis e informasen a esta Agencia en el plazo de un mes, de las acciones llevadas a cabo para adecuarse a los requisitos previstos en la normativa de protección de datos.

Se solicitaba la siguiente información:

- Descripción detallada y cronológica de los hechos.
- Causas que hicieron posible el incidente.
- Personas y categoría de datos personales afectadas.
- Posibles consecuencias para los afectados.
- Acciones tomadas para solucionar el incidente.
- Los análisis de riesgos y medidas de seguridad preventivas concluidas, así como evaluaciones de impacto en su caso.

- Copia del Registro de Actividades de Tratamientos donde se ha producido incidente.
- Información sobre la posible comunicación a las personas afectadas.
- Información sobre la posible notificación del incidente ante esta Agencia.

SÉPTIMO: En fecha 23 de enero de 2023 y registros de entrada REGAGE23e00004620337 y REGAGE23e00004620561 se recibe respuesta por parte de MARKTEL al traslado de la primera reclamación., adjuntando los siguientes documentos:

- (...).

De tal documentación se extrae la siguiente información relevante:

- (...):

(...)

(...)

(...):

(...)

(...):

- (...)

Se confirma el siguiente listado de medidas preventivas que existían implantadas por MARKTEL:

- (...)

Se confirma el listado de medidas reactivas adoptadas por MARKTEL tras el incidente:

- (...)

(...)

- En la respuesta al traslado también se adjunta documento con el análisis de riesgos de fecha de creación mayo de 2018 y actualizado el 20 de octubre de 2022, de este documento se extrae la siguiente información relevante:

(...):

- (...)

- Se adjunta el Registro de Actividades de Tratamiento (RAT) de MARKTEL actuando como encargado de tratamiento de ORANGE/JAZZTEL, recogiendo la siguiente información:

(...)

- En relación con la comunicación a los afectados, se afirma que desde MARKTEL no se realizó ninguna notificación al actuar en todo momento como encargado de tratamiento de los datos personales afectados, se afirma que MARKTEL se limitó a seguir las instrucciones del responsable afectado.

OCTAVO: En fecha 27 de enero de 2023 y registros de entrada REGAGE23e00005596907 y REGAGE23e00005596460 se recibe respuesta al traslado de la primera reclamación por parte de ORANGE, del análisis de la documentación aportada se extrae la siguiente información relevante:

- (...)
- (...)
- (...)
- (...):

(...)

- (...)
- (...)
- (...):

(...)

NOVENO: Se reciben asimismo las respuestas dadas por MARKTEL y ORANGE a la segunda reclamación, de las que no se obtiene información adicional relevante a la ya analizada en los antecedentes anteriores. De la respuesta dada por ORANGE BANK (en fecha 22 de enero de 2023 y registro de entrada REGAGE23e00004368876) se extrae la siguiente información relevante:

- (...)
- (...)
- (...)
- (...)

DÉCIMO: Los días 18 y 28 de febrero de 2023 ambas reclamaciones fueron admitidas a trámite.

UNDÉCIMO: La Subdirección General de Inspección de Datos procedió a la realización de actuaciones previas de investigación para el esclarecimiento de los hechos en cuestión, en virtud de las funciones asignadas a las autoridades de control en el artículo 57.1 y de los poderes otorgados en el artículo 58.1 del Reglamento (UE) 2016/679 (Reglamento General de Protección de Datos, en adelante RGPD), y de conformidad con lo establecido en el Título VII, Capítulo I, Sección segunda, de la LOPDGDD, teniendo conocimiento de los siguientes extremos:

(...):

- (...):

(...)

- (...)

Teniendo en cuenta la información obtenida en este punto de la investigación, en fecha 29 de mayo de 2023 se decide realizar nuevo requerimiento de información dirigido a MARKTEL, ORANGE ESPAGNE, ORANGE BANK, marcado por las siguientes líneas de investigación:

- Para MARKTEL:

- a) Investigar todos los posibles responsables de tratamiento afectados por la filtración de los datos.
- b) Solicitar el informe de auditoría realizado por Deloitte.
- c) Investigar el vector de ataque de la brecha.
- d) Solicitar la acreditación de las medidas preventivas listadas y referenciadas.

- Para ORANGE ESPAGNE:

- a) Investigar la correcta formalización de los encargos de tratamiento.
- b) Investigar la posible pérdida de disponibilidad de los datos por la brecha.
- c) Investigar la correcta comunicación a los afectados.

- Para ORANGE BANK:

- a) Investigar la responsabilidad proactiva en los análisis de riesgos como responsable de tratamiento y la comunicación a los afectados.

En fecha 19 de junio de 2023 y registros de entrada REGAGE23e00039953302, REGAGE23e00039953372, REGAGE23e00039953646, REGAGE23e00039953646, REGAGE23e00039953771 y REGAGE23e00039953828 se recibe respuesta al requerimiento por parte de MARKTEL, de su análisis por el inspector se extrae la siguiente información relevante:

- (...)
- (...):
 (...)

En cuanto a las medidas de seguridad se recoge en la cláusula 17 "Protección de Datos" apartado 2.6.d) del contrato lo siguiente:

(...):

- (...)
- (...)
- (...)
- (...)

(...)



El Anexo III de la Seguridad de la Información adjunto al citado Contrato, establece lo siguiente:

(...)

1. MEDIDAS ESPECÍFICAS EN MATERIA DE SEGURIDAD DE LA INFORMACIÓN

(...)

1. (...):

(...)

(...)

2. (...):

(...)

(...):

a. (...)

b. (...)

c. (...):

1(...):

o (...)

o (...)

1 (...)

1 (...)

3. (...):

(...)

(...):

1 (...)

(...)

(a) (...)

(b) (...)



(c) (...))

) (...)
) (...)
) (...)
) (...)
) (...)

4. (...):

(...):

) (...)
) (...)

(...)

5. (...):

(...):

(a) (...))

(b) (...))

(c) (...))

(d) (...):

o (...)
o (...)
o (...)
o (...)
o (...)

6. (...):

(...)

7. **Responsabilidad del PROVEEDOR por incumplimiento del presente Anexo.**

(...).

- (...):

“(...).”

- (...).

- (...).

- (...):

“(...)”

- (...):

(...)

- (...)

En fecha 19 de junio de 2023 y registro de entrada REGAGE23e00039958481 se recibe respuesta al requerimiento por parte de ORANGE BANK, de su análisis por el inspector se extrae la siguiente información relevante:

- Se acredita el registro de incidentes con la brecha documentada, del análisis de este registro se obtiene:

)a En relación con el contexto de la brecha: “(...)”

)b Medidas correctivas adoptadas por ORANGE BANK adicionales a las implantadas por MARKTEL en su plan de acción:

▪ (...)

▪ (...)

▪ (...)

)c Desde ORANGE ESPAGNE se ha remitido la comunicación del incidente a las personas afectadas y afirman que, para evitar confusión de los clientes ORANGE BANK, este responsable decide adherirse a dicha comunicación.

- Se realiza un análisis documentado sobre el impacto o alcance del incidente que concluye con la necesidad de notificar la brecha.

- Se aporta la siguiente cronología detallada del incidente:

)a (...)

- (...)

En fecha 20 de junio de 2023 y registros de entrada REGAGE23e00040164903 y REGAGE23e00040165559 se recibe respuesta al requerimiento por parte de ORANGE ESPAGNE, de su análisis se extrae, entre otra, la siguiente información relevante:

- Se aporta copia del contrato de encargo suscrito entre ORANGE ESPAGNE y MARKTEL, ya analizado en puntos anteriores.

- En relación con la acreditación de la notificación de la brecha a cada responsable afectado, se aporta captura de pantalla de los correos electrónicos enviados en el 25 de octubre de 2022 dirigidos a ORANGE BANK, el contenido es el siguiente:

“(...)”

“(...)”

- Se obtienen las siguientes afirmaciones relevantes realizadas por parte de ORANGE ESPAGNE:

)a “(...)”

)b “(...)”

)c “(...)”

En fecha 26 de octubre de 2023 se decide realizar un último requerimiento de información a ORANGE ESPAGNE marcado por la siguiente línea de investigación:

- (...)

En fecha 7 de noviembre de 2023 y registro de entrada REGAGE23e00075433461 se recibe respuesta al requerimiento anterior, de su análisis se extrae la siguiente información relevante:

- Se aportan dos facturas de clientes afectados y se verifica por parte del inspector la existencia del siguiente texto incorporado en el pie de factura:

” (...)”

DUODÉCIMO: En fecha 16 de febrero de 2024, la Directora de la Agencia Española de Protección de Datos acordó iniciar procedimiento sancionador a la entidad investigada, con arreglo a lo dispuesto en los artículos 63 y 64 de la Ley 39/2015, de 1 de octubre, del Procedimiento Administrativo Común de las Administraciones Públicas (en adelante, LPACAP), por la presunta infracción del artículo 5.1.f), tipificada en el artículo 83.5 del RGPD.

El acuerdo de inicio fue enviado, conforme a las normas establecidas en la LPACAP, mediante notificación electrónica, no siendo recibido por el responsable, dentro del plazo de puesta a disposición, entendiéndose rechazada conforme a lo previsto en el art. 43.2 de la LPACAP, en fecha 27 de febrero de 2024, como consta en el certificado que obra en el expediente.

Asimismo, se envió una copia por correo postal que fue notificada fehacientemente en fecha 19 de febrero de 2024. En dicha notificación, se le recordaba su obligación de relacionarse electrónicamente con la Administración, y se le informaba de los medios de acceso a dichas notificaciones, reiterando que, en lo sucesivo, se le notificaría exclusivamente por medios electrónicos.

DECIMOTERCERO: En contestación al escrito en el que solicitaba la ampliación del plazo que fue concedido para formular alegaciones, así como copia de expediente, en fecha 23 de febrero de 2024, se acordó ampliar el plazo para formular alegaciones hasta un máximo de diez días, que debían computarse a partir del día siguiente a aquel en el que recibiera la copia del expediente.

En cumplimiento de lo dispuesto en el artículo 53.1.a) de la LPACAP, en fecha 14 de marzo de 2024, se procedió a remitir a la entidad investigada mediante mensajería, un soporte físico (CD o memoria USB) cifrado, con la copia completa del expediente administrativo solicitado, puesto que la copia del expediente solicitada tenía un tamaño que excedía el máximo permitido en el sistema Notific@, empleado por los órganos de la Administración para la práctica electrónica de sus notificaciones.

En la misma fecha se enviaba de forma independiente otro documento a través de la citada plataforma Notific@ en el que se facilitaba la clave para acceder a la documentación incluida en el soporte físico y se acordaba ampliar el plazo para formular alegaciones hasta un máximo de diez días, que debían computarse a partir del día siguiente a aquel en el que recibiera la copia del expediente.

DECIMOCUARTO: En fecha 3 de abril de 2024, en contestación al escrito por el que solicitaba copia del CD aportado por Orange, se remitió la copia de este, de acuerdo con lo dispuesto en el art. 53.1 a) de la Ley 39/2015, de 1 de octubre, del Procedimiento Administrativo Común de las Administraciones Públicas (en adelante LPACAP).

Respecto a la petición de la entidad para que se suspendiera el plazo de alegaciones hasta que se le diera traslado de la copia del expediente, el órgano instructor del procedimiento indicó que conforme a lo dispuesto en el artículo 29 de la LPACAP, los términos y plazos fijados en ella, obligan a la Administración Pública y a los interesados y aunque contempla la posibilidad de que aquéllos sean ampliados no regula la suspensión por las razones invocadas.

DECIMOQUINTO: Notificado el citado acuerdo de inicio conforme a las normas establecidas en la LPACAP, la entidad investigada presentó escrito de alegaciones.

DECIMOSEXTO: En fecha 27 de diciembre de 2024, se formuló propuesta de resolución, proponiendo:

<< Que por la Directora de la Agencia Española de Protección de Datos se sancione a ORANGE BANK, S.A. SUCURSAL EN ESPAÑA, con NIF W2503011E,

-por la infracción del artículo 5.1.f) del RGPD, tipificada conforme a lo dispuesto en el artículo 83.5 del RGPD, calificada como muy grave a efectos de prescripción, en el artículo 72.1 a) de la LOPDGDD, con una multa de 1. 500.000 euros.

Que por la Directora de la Agencia Española de Protección de Datos se ordene a ORANGE BANK, S.A. SUCURSAL EN ESPAÑA, con NIF W2503011E, que en virtud del artículo 58.2.d) del RGPD, en el plazo de seis meses a partir de la firmeza de la resolución con la que finalice el presente procedimiento, acredite haber procedido a la implantación de las medidas necesarias para garantizar la confidencialidad de los

datos sujetos a su tratamiento así como que informe a esta Agencia, en el mismo plazo, sobre las medidas adoptadas.>>

La citada propuesta de resolución fue enviada, conforme a las normas establecidas en la LPACAP, mediante notificación electrónica, siendo recibida en fecha 7 de enero de 2025.

DECIMOSÉPTIMO: En fecha 10 de enero de 2025, ORANGE BANK, S.A. SUCURSAL EN ESPAÑA, presentó un escrito a través del cual solicitaba la ampliación del plazo conferido para presentar alegaciones.

En fecha 14 de enero de 2025, el órgano instructor del procedimiento acordó la ampliación de plazo hasta un máximo de cinco días, que debían computarse a partir del día siguiente a aquel en el que finalizara el primer plazo de alegaciones.

El citado acuerdo fue notificado en fecha 15 de enero de 2025, como consta en el acuse de recibo que obra en el expediente.

DECIMOCTAVO: En fecha 14 de enero de 2025, ORANGE BANK, S.A. SUCURSAL EN ESPAÑA presentó escrito de alegaciones a la Propuesta de Resolución, en el que, en síntesis, manifiesta que:

1. Argumentos nuevos de la propuesta de resolución.

Expone que en el escrito se tienen por reiterados todos y cada uno de los hechos que se describieron en el escrito inicial de alegaciones, así como los fundamentos de derecho que se razonaron en el mismo y, en este trámite de audiencia frente a la propuesta de resolución se añaden únicamente los razonamientos, argumentos y elementos necesarios para responder y discutir aquellos aspectos en los que la propuesta de resolución innova frente al acuerdo de apertura del expediente sancionador.

2. En relación con los hechos.

2.1 Número de datos afectados por la brecha de seguridad.

Alega que la brecha de seguridad que es objeto de análisis en este expediente ha afectado exclusivamente (...).

Y añade que cualquier cita de datos diferentes a los que corresponden a la responsabilidad de Orange Bank S.A. Sucursal en España tiene que eliminarse de los documentos del expediente, porque no deben influir en la valoración de la responsabilidad que se imputa a la entidad, pero, sin embargo, desfiguran la relevancia de los hechos de los que debe responder.

2.2 Número de datos declarados por Orange Bank S.A. Sucursal en España.

Expone que Orange Bank S.A. Sucursal en España ha notificado a la Agencia la brecha de seguridad desde el primer momento en que tuvo conocimiento de ella, y ha

declarado igualmente todas las circunstancias que concurrían en dicha incidencia según las iba conociendo.

Por este motivo, manifiesta que, en la primera declaración, de 28/10/2022 se indicó que, de acuerdo con la información con que se contaba en ese momento, los datos afectaban (...)

Considera que nuevamente, esta referencia a la actualización que incide con tanto detalle en el dato original y actualizado no tiene influencia alguna en la valoración de la responsabilidad que se imputa a Orange Bank S.A. Sucursal en España, pero desfigura la imagen de la entidad y genera la idea de que ha intentado ocultar datos y burlar a la Administración.

2.3 Números IBAN sin ofuscar.

(...)

(...)

En definitiva, expone que de los dos años durante los que Orange Bank S.A. Sucursal en España se sirvió de los servicios de Marktel, la mitad del periodo los datos estuvieron sin ofuscar y la otra mitad ofuscados.

(...)

3. Sobre la incompetencia de la Agencia Española de Protección de Datos.

Manifiesta que Orange Bank S.A. Sucursal en España es, como indica su nombre, una sucursal del banco francés Orange Bank S.A., sociedad financiera francesa establecida en Montreuil Francia. Orange Bank S.A. que está participada al 100% por Orange SA, matriz del grupo France Telecom.

Expone que, al abrir una sucursal en España, la sociedad francesa, Orange Bank SA, no ha modificado en absoluto su personalidad jurídica ni su domicilio ni su nacionalidad. La sucursal es una oficina de la sociedad francesa. Por tanto, para la imputación de la responsabilidad sólo puede tenerse en consideración a la sociedad francesa. Resulta imposible imputar esa responsabilidad a la sucursal, porque carece de personalidad jurídica propia, de modo que no es posible acusarla ni imponerle la eventual sanción. Jurídicamente, cualquier actuación ante la sucursal es un acto ejecutado frente a la sociedad titular de la sucursal.

Considera que el hecho de estar inscrita en el Registro Mercantil, contar con un NIF español y con una autorización del Banco de España son únicamente el reflejo del principio de unidad territorial, cuya eficacia requiere de ciertas formalidades tributarias y regulatorias para garantizar el cumplimiento de las normas y competencias singulares de cada Estado Miembro en aquellos aspectos y ámbitos en los que la competencia es exclusiva y no reflejo de una competencia común.

En definitiva, alega que la AEPD no puede actuar frente a la sucursal en España de la sociedad francesa Orange Bank S.A., porque la sucursal carece de personalidad jurídica propia y diferenciada de la sociedad francesa. Cualquier actuación frente a la

sociedad francesa Orange Bank S.A., con independencia de si se notifica a su sucursal en España o a cualquier otra sede de la compañía, sólo podrá realizarla la autoridad de control principal.

Es decir, considera que solo podía haber actuado la CNIL francesa, que es el único interlocutor frente a Orange Bank S.A. en relación con el tratamiento transfronterizo que ha realizado en España la sociedad a través de su sucursal en España.

En definitiva, dado que el tratamiento de datos objeto de este procedimiento es transfronterizo, en cuanto que el problema se ha suscitado por la actividad en España de una sociedad de nacionalidad francesa, Orange Bank S.A., a través de su sucursal, la única autoridad de control con competencia para actuar frente a Orange Bank S.A. es la autoridad de control principal, es decir, la competente en el Estado Miembro de su sede principal. La CNIL es la única autoridad que podía haber actuado frente a Orange Bank S.A.

En definitiva, concluye que la falta de competencia y de procedimiento que se denuncia provoca que las actuaciones realizadas por la AEPD sean nulas de pleno derecho, según establece el artículo 47.1 de la L 39/2015.

4. Sobre la caducidad de las actuaciones previas.

Entiende que el cómputo del plazo de caducidad de las actuaciones previas comenzó en el momento en que la Administración realizó la primera actuación material de investigación, es decir, el día 23 de diciembre de 2022, cuando la AEPD requirió a Marktel y al operador de telecomunicaciones para que aportaran información en relación con la reclamación de A.A.A. en el marco de los citados expedientes.

Y que, por tanto, las actuaciones previas de investigación - EXP202213536 y EXP20221353- caducaron el 23/12/2023.

Alega que la Agencia tenía la obligación legal de declarar la caducidad del expediente y ordenar el archivo de las actuaciones, según establece el artículo 25.1 b) de la Ley 39/2015.

Sin embargo, la Agencia ha continuado adelante con la tramitación de un procedimiento que, a partir de ese momento está afectado por una causa indiscutible de nulidad, de modo que la incoación del expediente sancionador y su instrucción son nulos.

Por último, en relación con este punto, quiere poner de manifiesto que la propuesta de resolución incluye numerosos argumentos relativos a la no caducidad del expediente sancionador, que no se ha planteado por esta parte y, por ello, no tienen relación alguna con esta discusión jurídica.

5. Sobre la contradicción entre el acuerdo de inicio del expediente y el archivo de actuaciones de 28 de diciembre de 2022.

Manifiesta que el 28/12/2022, la División de Innovación Tecnológica de la AEPD notificó a Orange Bank S.A. Sucursal en España el archivo de la investigación relativa a la brecha de seguridad notificada y anunció que no existirían actuaciones adicionales sobre los hechos notificados (decisión REGAGE22e00056805824).

Sin embargo, expone que la Agencia ha abierto un expediente sancionador en el que ni siquiera revoca formalmente ese acuerdo de 28/12/2022 que le beneficiaba.

Considera que la notificación de 28/12/2022 genera unos derechos en Orange Bank S.A. Sucursal en España que no pueden eliminarse de la realidad jurídica con fundamento en meras formalidades. Y que si, al recibir las denuncias, la Agencia consideró que existían razones para actuar frente a Orange Bank S.A. Sucursal en España, tenía que haber revocado la declaración antes manifestada mediante el procedimiento específico que establece el artículo 107 de la Ley 39/2015.

6. Existe un ánimo persecutorio de la Agencia frente a Orange Bank S.A. Sucursal en España.

Manifiesta que la propuesta de resolución utiliza una redacción claramente tendenciosa para desvirtuar la imagen de Orange Bank S.A. Sucursal en España y justificar así el enorme importe de la sanción que propone en cuanto al número de registros afectados, el número de códigos IBAN sin ofuscar y la falta de protección del código IBAN.

Considera que la propuesta de resolución produce una imagen de Orange Bank S.A. Sucursal en España de absoluta irresponsabilidad en la protección de los datos personales de su responsabilidad y del abandono a su suerte de los datos de sus clientes, cuando en realidad Orange Bank S.A. Sucursal en España seleccionó un proveedor de máximo nivel y exigió contractualmente un nivel de seguridad totalmente adecuado.

7. Tamaño de Orange Bank S.A. Sucursal en España.

Desea incidir en el hecho de que la propuesta de resolución parte de un hecho falso al insistir en la misma idea en que ya incidía el acuerdo de inicio del expediente: Orange Bank S.A. Sucursal en España es una gran empresa.

Informa que la actividad de Orange Bank S.A. Sucursal en España responde a unos parámetros muy diferentes:

- (...)

- (...)

- (...) €

Alega que ha aportado el Impuesto de Sociedades de la entidad (Modelo 200) correspondiente al ejercicio 2022, presentado a la AEAT (...).

8. Falta de proporcionalidad de la sanción propuesta.

Considera que el importe de la sanción que se procura en la propuesta de resolución, 1.500.000 €, es comparable con las multas que se han impuesto a los grandes bancos españoles (Caixabank, BBVA) pero Orange Bank S.A. Sucursal en España es infinitamente más pequeño que estas entidades con más de 15 millones de clientes.

Alega que Orange Bank S.A. Sucursal en España tiene un volumen de negocio (...), según se ha acreditado mediante las declaraciones tributarias del banco. Y que la

Agencia se apoya en una cifra de negocio que es imposible saber de dónde procede y que no se admite por esta parte. Esa cifra de negocio es falsa y no puede atribuirse ni a Orange Bank S.A., ni a la Sucursal en España de Orange Bank S.A.

Manifiesta que no puede tenerse en consideración para calcular el importe de la sanción y, por tanto, los argumentos relativos a la proporcionalidad que realiza la Agencia en la propuesta de resolución resultan inadmisibles. La Agencia fundamenta esa pretendida proporcionalidad en unas cifras que nadie sabe de dónde han salido.

9. Calificación de la infracción como muy grave.

Aclara que la infracción que se imputa a Orange Bank S.A. Sucursal en España se deriva de un fallo en el sistema de seguridad que tenía implantado al tiempo de suceder la brecha de seguridad y que, sin embargo, no la impidió.

Considera que de los Hechos Probados se deduce sin duda alguna que Orange Bank S.A. Sucursal en España había establecido unas condiciones de seguridad que eran adecuadas para los riesgos que se generaban del tratamiento de los datos que se vieron afectados por la brecha de seguridad.

Manifiesta que en el expediente sancionador existe prueba suficiente que acredita que Orange Bank S.A. Sucursal en España había implantado un sistema de seguridad que trataba de evitar lo que, no obstante, terminó sucediendo y que, concretamente, incluía la obligación del proveedor de servicios Marktel de mantener los datos cifrados, utilizar canales de comunicación cifrados y establecer en sus sistemas herramientas antimalware.

Además, tan pronto como Orange Bank S.A. Sucursal en España fue consciente de que el dato del IBAN se conservaba en los sistemas de Marktel sin ofuscar, inició los trámites para conseguir que se mitigara el riesgo que generaba la conservación del dato completo, lo que terminó consumiendo un año entero de desarrollo e implementación, pero a partir de noviembre de 2022, los IBAN se alojaron en los sistemas protegidos mediante la ofuscación. Estas previsiones dieron lugar a que la mitad de los datos de Orange Bank S.A. Sucursal en España que sufrieron las consecuencias de la brecha de seguridad estuvieran protegidos por esta previsión.

Expone que Orange Bank S.A. Sucursal en España había establecido un sistema de seguridad, había evaluado los riesgos que concurrían en los datos que sufrieron las consecuencias de la brecha de seguridad, había implementado las medidas de seguridad apropiadas, mediante la exigencia al proveedor de servicios de las medidas de seguridad adecuadas y había mantenido un sistema continuado de evaluación y adecuación, de forma que a mitad del periodo del servicio, se había mitigado el riesgo de que el IBAN estaba sin ofuscar.

Concluye que no puede imputarse a Orange Bank S.A. Sucursal en España una falta completa de previsión y responsabilidad en la protección de los datos y, por ello, no puede achacársele la infracción de los principios del artículo 5 del RGPD.

Y añade que cuando el responsable del tratamiento ha realizado adecuadamente los análisis de riesgos, ha definido un sistema de seguridad y se ha preocupado de su implementación, la existencia de una brecha de seguridad es un suceso que solo

puede generar responsabilidad si las previsiones realizadas y el seguimiento de la implementación es insuficiente.

10. Necesidad de que la propuesta de resolución se adecúe a las circunstancias de hecho que se han corregido o matizado.

Indica que en las alegaciones iniciales se puso de manifiesto que en el acuerdo de inicio del expediente existían ciertas imprecisiones respecto de los datos en los que se fundaba la imputación de la responsabilidad, y la Agencia se ha hecho eco de estas correcciones en el acuerdo de inicio del expediente.

Alega que efectivamente, el número de datos sometidos a la responsabilidad de Orange Bank S.A. Sucursal en España se limita a ser del 5,8% de los inicialmente imputados.

Añade que, además, se ha declarado probado que el dato del IBAN fue objeto de ofuscación a partir de noviembre de 2022.

Y, por último, que se ha declarado probado que el sistema de seguridad implementado por Orange Bank S.A. Sucursal en España incluía, entre otras, el cifrado de los datos alojados en el sistema del proveedor y la implementación de herramientas antimalware.

Estos datos afectan, a juicio de Orange Bank S.A. Sucursal en España, a la valoración de la responsabilidad que en su caso pudiera imputársele, y, por ello, esta responsabilidad debería verse modificada en la propuesta de resolución.

Sin embargo, manifiesta que la propuesta de resolución mantiene la sanción inicialmente advertida y no realiza valoración ni fundamentación alguna relativa a las razones por las que estos cambios no influyen en la imputación ni en la calificación de la responsabilidad, ni tampoco en el importe de la sanción inicialmente advertida.

En su virtud, solicita que se admita el escrito y se tenga por atendido el trámite de alegaciones a la propuesta de resolución, y que, a su vista, se acuerde:

1. La declaración de nulidad del expediente por falta de competencia.
2. Supletoriamente, la declaración de nulidad de las actuaciones a partir del momento en que caducaron las diligencias previas de investigación.
3. Supletoriamente, la nulidad del expediente por infracción del procedimiento para la declaración de lesividad de los actos declarativos de derechos.
4. Supletoriamente, la corrección en la resolución de las referencias inapropiadas a datos que no reflejan la realidad de este expediente sancionador.
5. Adicionalmente a la anterior, el archivo de las actuaciones, porque no existen razones para imputar responsabilidad alguna a Orange Bank S.A. Sucursal en España.
6. Supletoriamente a la anterior, la graduación de la infracción como grave y no muy grave.

7. Adicionalmente a la anterior, la adecuación del importe de la sanción al tamaño y economía real de Orange Bank S.A. Sucursal en España.

8. Adicionalmente a las anteriores 6. y 7., la adecuación del importe de la sanción a las cifras reales de datos bajo la responsabilidad de Orange Bank S.A. Sucursal en España.

A la vista de todo lo actuado, por parte de la Agencia Española de Protección de Datos en el presente procedimiento se consideran hechos probados los siguientes,

HECHOS PROBADOS

PRIMERO: (...).

(...):

- (...)

SEGUNDO: En fechas 5 de octubre de 2022 y 4 de noviembre de 2022, se reciben dos notificaciones de brechas de seguridad por parte de MARKTEL con número de registro de entrada REGAGE22e00044254458 y REGAGE22e00049917967.

Del contenido de ambas notificaciones se extrae la siguiente información relevante:

- Descripción de la brecha: “(...)”
- (...).

TERCERO: En fechas 22 de octubre de 2022 y 21 de noviembre de 2022 se recibieron dos notificaciones de brecha por parte de ORANGE ESPAGNE SAU, de su contenido se extrae la siguiente información:

- Descripción: “(...)”

CUARTO: En fecha 28 de octubre de 2022 y registro de entrada REGAGE22e00048666972 se recibió notificación de brecha de seguridad por parte del responsable de tratamiento ORANGE BANK SA (SUCURSAL EN ESPAÑA) con la siguiente información destacada:

- Descripción: “(...)”

QUINTO: (...):

- (...)
- (...)
- (...)
- (...)
- (...)
- (...)

(...).

SEXTO: En relación con la responsabilidad de los datos personales filtrados, ha quedado constatado que MAKTEL actuaba como subencargado de tratamiento subcontratado por ORANGE ESPAGNE al prestar el servicio de recobro de impagos de clientes que adquirirían deudas por la compra de terminales a plazos.

ORANGE ESPAGNE actuaba con un doble rol con respecto de estos datos, por un lado, como responsable de tratamiento de los datos personales facilitados en la compra, y por otro como encargado de tratamiento, entre otros, de ORANGE BANK al existir una cesión de derechos de créditos de las deudas contraídas en la venta a plazos del terminal, encargándose en el propio contrato a ORANGE ESPAGNE la gestión de las operaciones de recobro en caso de impago.

SÉPTIMO: El 1 de julio de 2020 ORANGE y ORANGE BANK firmaron un contrato de prestación de servicios en el que se recoge expresamente que MERKEL está subcontratada por ORANGE.

Consta asimismo en el apartado compromisos en el tratamiento de información de carácter personal” que “Siempre que se traen datos personales, el Cedente cumplirá con las condiciones recogidas en el contrato, así como toda la normativa de protección de datos vigente en cada momento. En el supuesto de que el Cedente adquiriera, en virtud del contrato, la condición de Encargado de Tratamiento de datos de carácter personal, garantizará, teniendo en cuenta el estado de la técnica, los costes de aplicación, y la naturaleza, el alcance, el contexto y los fines del tratamiento, así como riesgos de probabilidad y gravedad variables para los derechos y libertades de las personas físicas, que aplicará medidas técnicas y organizativas apropiadas para garantizar un nivel de seguridad adecuado al riesgo.

Al evaluar la adecuación del nivel de seguridad tendrá particularmente en cuenta los riesgos que presente el tratamiento de datos, en particular como consecuencia de la destrucción, pérdida o alteración accidental o ilícita de datos personales transmitidos, conservados o tratados de otra forma, o la comunicación o acceso no autorizados a dichos datos, de conformidad con lo establecido en el Reglamento (UE) 2016/679 del Parlamento Europeo y del Consejo, de 27 de abril de 2016, relativo a la protección de las personas físicas en lo que respecta al tratamiento de datos personales y a la libre circulación de estos datos y por el que se deroga la Directiva 95/46/CE (de ahora en adelante, RGPD).

Asimismo, el Cedente proporcionará los datos de contacto del Delegado de Protección de Datos de Orange.”

OCTAVO: ORANGE ESPAGNE firmó un contrato de encargado con MARKEL con vigencia retroactiva a partir del 1 de enero de 2022, el cual incorpora el objeto del encargo de tratamiento, los datos personales afectados, las categorías de interesados, las obligaciones asumidas por el encargado y las medidas de seguridad.

En dicho contrato, la Cláusula 17 relativa a la protección de datos, establece en cuanto a las medidas de seguridad en el apartado 2.6.d) que:

(...):

- (...)

- (...)
- (...)
- (...)

(...).

ANEXO III

MEDIDAS ESPECÍFICAS EN MATERIA DE SEGURIDAD DE LA INFORMACIÓN Y CÓDIGO DE CONDUCTA DE PROVEEDORES Y CONTROL DE FRAUDE Y REVENUE ASSURANCE

(...)
(...)

NOVENO: En relación con el cumplimiento de las obligaciones de notificación de la brecha tanto ante esta Agencia como a los afectados ha quedado acreditado la siguiente cronología de hechos:

- (...)
- (...)
- (...)
- (...)
- (...)

DÉCIMO: Se ha constatado la implantación del siguiente listado de medidas preventivas por parte de MARKTEL en momentos previos al incidente:

- (...)
- (...)
- (...)
- (...)
- (...)
- (...)
- (...)
- (...)
- (...)
- (...)
- (...)

UNDÉCIMO: Se ha constatado la implantación y despliegue del siguiente listado de medidas reactivas adoptadas por MARKTEL:

- (...)
- (...)
- (...)

- (...)
- (...)
- (...)
- (...)

DUODÉCIMO: En relación con los clientes afectados por la brecha cuyos datos eran responsabilidad de ORANGE BANK (tras la cesión de los derechos de créditos de ORANGE ESPAGNE), ha quedado acreditado que estos clientes fueron informados de esta cesión de créditos en la propia factura de compra, incluyéndose un texto en el pie de factura con la siguiente información:

- Que ORANGE BANK es responsables de los derechos de crédito de la deuda contraída y de sus datos personales.
- Que ORANGE BANK había delegado la gestión del cobro al propio ORANGE ESPAGNE.
- La existencia de los derechos de protección de datos y la forma de ejercerlos.
- Una dirección de correo electrónico para obtener información adicional.

DECIMOTERCERO: De las respuestas dadas por ORANGE BANK a esta AEPD con registros de entrada REGAGE23e00004368876 y REGAGE23e00039958481 se extrae que ORANGE ESPAGNE notificó el incidente a ORANGE BANK en fecha 25 de octubre de 2022, (...).

(...).

FUNDAMENTOS DE DERECHO

I Competencia

De acuerdo con los poderes que el artículo 58.2 del Reglamento (UE) 2016/679 (Reglamento General de Protección de Datos, en adelante RGPD), otorga a cada autoridad de control y según lo establecido en los artículos 47, 48.1, 64.2 y 68.1 de la Ley Orgánica 3/2018, de 5 de diciembre, de Protección de Datos Personales y Garantía de los Derechos Digitales (en adelante, LOPDGDD), es competente para resolver este procedimiento, la Presidencia de la Agencia Española de Protección de Datos.

Asimismo, el artículo 63.2 de la LOPDGDD determina que: *"Los procedimientos tramitados por la Agencia Española de Protección de Datos se registrarán por lo dispuesto en el Reglamento (UE) 2016/679, en la presente ley orgánica, por las disposiciones reglamentarias dictadas en su desarrollo y, en cuanto no las contradigan, con carácter subsidiario, por las normas generales sobre los procedimientos administrativos."*

II Cuestiones previas

ORANGE BANK S.A: es una empresa del sector financiero que en el ejercicio de su actividad profesional trata una gran cantidad de datos de carácter personal,

entendiendo por dato de carácter personal: *“toda información sobre una persona física identificada o identificable”*.

Realiza la actividad de tratamiento en la que ha tenido lugar la violación de la seguridad de los datos personales en su condición de responsable del tratamiento, dado que es quien determina los fines y medios de tal actividad, en virtud del artículo 4.7 del RGPD:

«responsable del tratamiento» o «responsable»: la persona física o jurídica, autoridad pública, servicio u otro organismo que, solo o junto con otros, determine los fines y medios del tratamiento; si el Derecho de la Unión o de los Estados miembros determina los fines y medios del tratamiento, el responsable del tratamiento o los criterios específicos para su nombramiento podrá establecerlos el Derecho de la Unión o de los Estados miembros.

Se considera persona física identificable aquella cuya identidad pueda determinarse, directa o indirectamente, en particular mediante un identificador, como por ejemplo un nombre, un número de identificación, datos de localización, un identificador en línea o uno o varios elementos propios de la identidad física, fisiológica, genética, psíquica, económica, cultural o social de dicha persona.

Asimismo, debe entenderse por tratamiento *“cualquier operación o conjunto de operaciones realizadas sobre datos personales o conjuntos de datos personales, ya sea por procedimientos automatizados o no, como la recogida, registro, organización, estructuración, conservación, adaptación o modificación, extracción, consulta, utilización, comunicación por transmisión, difusión o cualquier otra forma de habilitación de acceso, cotejo o interconexión, limitación, supresión o destrucción”*.

El artículo 4 apartado 12 del RGPD define, *«violación de la seguridad de los datos personales»:* *como toda violación de la seguridad que ocasione la destrucción, pérdida o alteración accidental o ilícita de datos personales transmitidos, conservados o tratados de otra forma, o la comunicación o acceso no autorizados a dichos datos.*

En el presente caso, y a raíz de la investigación realizada como consecuencia de la notificación de la brecha de seguridad de datos personales en las circunstancias arriba indicadas, se han detectado posibles vulneraciones en la normativa de protección de datos.

La brecha está categorizada como una brecha de confidencialidad, al constatarse un acceso indebido a los datos personales tratados que cifró los datos.

Marktel Global Services S.A. (Marktel), subencargada del tratamiento de ORANGE BANK, sufrió un ataque en el que se vieron afectados datos personales. (...).

En relación con la responsabilidad de los datos personales filtrados, ha quedado constatado que MARKTEL actuaba como encargado de tratamiento de ORANGE ESPAGNE al prestar el servicio de recobro de impagos de clientes que adquirían deudas por la compra de terminales a plazos. No obstante, ORANGE ESPAGNE actuaba con un doble rol con respecto de estos datos, por un lado, como responsable de tratamiento de los datos personales facilitados en la compra, y por otro como encargado de tratamiento de ORANGE BANK al existir una cesión de derechos de

créditos de las deudas contraídas en la venta a plazos del terminal, encargando en el propio contrato a ORANGE ESPAGNE la gestión de las operaciones de recobro en caso de impago.

III Respuesta a las alegaciones al acuerdo de inicio

En respuesta a las alegaciones presentadas por la entidad investigada se debe señalar lo siguiente:

- Caducidad de las actuaciones previas.

Sobre la posible caducidad de actuaciones previas que la entidad investigada manifiesta en las alegaciones al acuerdo de inicio, se ha de indicar que las reclamaciones de las que trae causa el presente procedimiento fueron admitidas a trámite los días 18 y 28 de febrero de 2023 y que el presente procedimiento se inició el 16 de febrero de 2024, antes por tanto del transcurso del plazo de 12 meses fijado por la LOPDGDD para la caducidad de las actuaciones de investigación.

Sin perjuicio de lo anterior, debe señalarse, además, que el plazo de caducidad del presente procedimiento se computa desde la fecha en que se acuerda su inicio, esto es, desde el 27 de febrero de 2024, resultando improcedente añadir a ese cómputo, a efectos de medir la duración del expediente administrativo, ningún otro período, tal y como el tiempo de las actuaciones previas de investigación, o el tiempo que transcurra entre la finalización de esas actuaciones y la apertura del procedimiento, ni el tiempo correspondiente a la fase de admisión a trámite de las reclamaciones presentadas.

Así lo ha declarado repetidamente nuestro Tribunal Supremo. En Sentencia de 21/10/2015 se cita la Sentencia de 26/12/2007 (recurso 1907/2005), que declara lo siguiente:

"[...] el plazo del procedimiento [...] se cuenta desde la incoación del expediente sancionador, lo que obviamente excluye del cómputo el tiempo de la información reservada"; "[...] la mayor o menor duración de la fase preliminar no lleva aparejada la caducidad del procedimiento ulterior".

También en Sentencia del Tribunal Supremo de 13/10/2011 (recurso 3987/2008) que examina un motivo de casación relativo al cómputo del plazo de caducidad del procedimiento, se declara lo siguiente:

"No podemos compartir el razonamiento que expone la Sala de instancia para fijar un dies a quo diferente al establecido por la Ley, señalando como fecha inicial del cómputo el día siguiente a la finalización de las diligencias previas informativas.

[...]

Pues bien, una vez realizadas esas actuaciones previas, el tiempo que tarde la Administración en acordar la incoación del procedimiento [...] podrá tener las consecuencias que procedan en cuanto al cómputo de la prescripción (extinción del derecho); pero no puede ser tomado en consideración a efectos de la caducidad, pues esta figura lo que pretende es asegurar que una vez iniciado el procedimiento la Administración no sobrepase el plazo de que dispone para resolver. En el fundamento tercero de la sentencia recurrida la Sala de instancia realiza una interpretación de la

norma que no es acorde con la naturaleza de la institución de la caducidad, pues a diferencia de la prescripción, que es causa de extinción del derecho o de la responsabilidad de que se trate, la caducidad es un modo de terminación del procedimiento por el transcurso del plazo fijado en la norma, por lo que su apreciación no impide, si no ha transcurrido el plazo establecido para la prescripción de la acción de restablecimiento de legalidad urbanística por parte de la Administración, la iniciación de un nuevo procedimiento”.

Por lo que el planteamiento que la entidad investigada realiza sobre esta cuestión en sus alegaciones no se ajusta a Derecho.

- Falta de legitimación pasiva de Orange Bank Sucursal en España y falta de competencia territorial de la AEPD.

En cuanto a la falta de legitimación pasiva de Orange Bank Sucursal en España y la falta de competencia territorial de la AEPD, debemos señalar que esta Agencia de Protección de Datos ha accedido a la Información Mercantil interactiva de los Registros Mercantiles de España, para obtener información sobre la entidad ORANGE BANK SA SUCURSAL EN ESPAÑA, (...). Y que por tanto tiene personalidad jurídica propia.

En consecuencia, esta Agencia considera no sólo la responsabilidad directa de ORANGE BANK SA SUCURSAL EN ESPAÑA en los hechos y en los que la AEPD es competente para sancionar, sino que, además, la entidad tiene prerrogativas suficientes como para decidir sobre los tratamientos realizados en España de sus clientes y, por tanto, dichos tratamientos se encuentran dentro del ámbito competencial de la Agencia Española protección de datos.

- Contradicción entre el acuerdo de inicio del expediente y el escrito de 28 de diciembre de 2022.

En el encabezado del escrito de 28 de diciembre de 2022 citado por ORANGE BANK consta “DIVISIÓN DE INNOVACIÓN TECNOLÓGICA” y finaliza indicando que dicha División no tiene previstas otras actuaciones.

Por tanto, en contra de lo que afirma la entidad investigada, este escrito no tiene carácter decisorio, ni por su contenido (más bien es un “acuse de recibo” de la brecha notificada y que en modo alguno puede entenderse como si esta AEPD hubiese valorado que no concurría responsabilidad alguna por un supuesto incumplimiento de la normativa de protección de datos, lo que supondría el archivo de unas actuaciones -tal y como ha querido entender la entidad) ni tampoco por su forma, pues ni siquiera formalmente refleja una decisión, ni mucho menos una resolución de archivo de actuación alguna, pues para que ello sea así Resulta necesario que tales actuaciones se hayan iniciado.

Dicho escrito está encaminado a poner en conocimiento de ORANGE BANK la recepción de la notificación de la brecha acaecida y de su incorporación al registro de notificaciones de brechas, de acuerdo con lo determinado en el artículo 31.d) del Estatuto de la Agencia, aprobado mediante Real Decreto 389/2021, de 1 de junio, sin que pueda deducirse a la vista del mismo que la AEPD valoró y decidió que no

concurría responsabilidad alguna por un supuesto incumplimiento de la normativa de protección de datos. Únicamente informa que por la DIT no se realizarán más actuaciones, pero todo ello sin perjuicio de que puedan iniciarse otras actuaciones como resulta obvio.

Así, el artículo 13 del Estatuto de la AEPD se determinan las funciones de la Presidencia:

1. Corresponde a la Presidencia de la Agencia Española de Protección de Datos:

d) Dictar las resoluciones y directrices que requiera el ejercicio de las funciones de la Agencia, en particular las derivadas del ejercicio de las competencias previstas en el artículo 57 del Reglamento (UE) 2016/679 del Parlamento Europeo y del Consejo, de 27 de abril de 2016, y del ejercicio de los poderes de investigación y de los poderes correctivos dispuestos en el artículo 58 del citado Reglamento.

El artículo 57, Funciones, del RGPD en su letra h) establece que:

“1. Sin perjuicio de otras funciones en virtud del presente Reglamento, incumbirá a cada autoridad de control, en su territorio:

(...)

h) llevar a cabo investigaciones sobre la aplicación del presente Reglamento, en particular basándose en información recibida de otra autoridad de control u otra autoridad pública;

(...)

En cuanto a las funciones de la Subdirección General de Inspección de Datos de la AEPD el artículo 27 del Estatuto de la Agencia indica, en su apartado 1, que

“La Subdirección General de Inspección de Datos es el órgano administrativo, dependiente de la Presidencia de la Agencia Española de Protección de Datos, que desarrolla las competencias previstas en el artículo 57.1, letras f), g), h), i) y u) del Reglamento (UE) 2016/679 del Parlamento Europeo y del Consejo, de 27 de abril de 2016, y realiza las funciones de inspección y de instrucción necesarias para el ejercicio de los poderes de investigación establecidos en el artículo 58.1, letras a), b), d), e) y f) y de los poderes correctivos dispuestos en el artículo 58.2, letras a), b), c), d), f), g), i) y j), ambos del citado Reglamento”

Y en el apartado 2 de este artículo 27 enumera las funciones que corresponden a la Subdirección General de Inspección de Datos de Datos, entre las que se encuentran, por lo que aquí interesa, las siguientes:

“a) La supervisión permanente del cumplimiento del Reglamento (UE) 2016/679 del Parlamento Europeo y del Consejo, de 27 de abril de 2016, de la Ley Orgánica 3/2018, de 5 de diciembre, y de las disposiciones que la desarrollen, por parte de los responsables y encargados de los tratamientos.

(...)

b) El ejercicio de las potestades de investigación definidas en el artículo 51 de la Ley Orgánica 3/2018, de 5 de diciembre.

(...)

d) La tramitación de los procedimientos en caso de posible vulneración de la normativa de protección de datos conforme a lo dispuesto en el título VIII de la Ley Orgánica 3/2018, de 5 de diciembre, incluyendo las reclamaciones de los ciudadanos por falta de atención en sus solicitudes de ejercicio de los derechos contemplados en los artículos 15 al 22 del Reglamento (UE) 2016/679 del Parlamento Europeo y del Consejo, de 27 de abril de 2016. Corresponde a la Subdirección General de Inspección de Datos el deber de informar al reclamante sobre el curso y el resultado de la reclamación presentada ante la Agencia Española de Protección de Datos, de acuerdo con lo dispuesto en el artículo 77.2 del citado Reglamento.

(...)"

Por tanto, para proceder al archivo de unas actuaciones investigación se requiere, primero, que se hayan iniciado (bien por haberse admitido a trámite una reclamación, bien por iniciativa propia, lo cual en ambos casos exige una resolución expresa firmada por la Directora), lo cual no había sucedido en el momento de emitirse el referido escrito de la División de Innovación Tecnológica (DIT) y, en segundo lugar, era necesaria una resolución expresa por parte de la Directora, archivando dichas actuaciones por entender, ahora sí, que de la información recabada en dichas investigaciones, no se concluye la existencia de infracción en la normativa de protección de datos, lo cual no se había producido.

En el presente caso, se presentaron dos reclamaciones por personas afectadas por la brecha, las cuales fueron admitidas a trámite por la AEPD en febrero de 2023 en cumplimiento del artículo 64 LOPDGDD.

Artículo 64. Forma de iniciación del procedimiento y duración.

1. Cuando el procedimiento se refiera exclusivamente a la falta de atención de una solicitud de ejercicio de los derechos establecidos en los artículos 15 a 22 del Reglamento (UE) 2016/679 del Parlamento Europeo y del Consejo, de 27 de abril de 2016, se iniciará por acuerdo de admisión a trámite, que se adoptará conforme a lo establecido en el artículo 65 de esta ley orgánica.

En este caso el plazo para resolver el procedimiento será de seis meses a contar desde la fecha en que hubiera sido notificado al reclamante el acuerdo de admisión a trámite. Transcurrido ese plazo, el interesado podrá considerar estimada su reclamación.

2. Cuando el procedimiento tenga por objeto la determinación de la posible existencia de una infracción de lo dispuesto en el Reglamento (UE) 2016/679 del Parlamento Europeo y del Consejo, de 27 de abril de 2016, y en la presente ley

orgánica, se iniciará mediante acuerdo de inicio, adoptado por propia iniciativa o como consecuencia de reclamación, que le será notificado al interesado.

Si el procedimiento se fundase en una reclamación formulada ante la Agencia Española de Protección de Datos, con carácter previo, esta decidirá sobre su admisión a trámite, conforme a lo dispuesto en el artículo 65 de esta ley orgánica.

Admitida a trámite la reclamación, así como en los supuestos en que la Agencia Española de Protección de Datos actúe por propia iniciativa, con carácter previo al acuerdo de inicio podrá existir una fase de actuaciones previas de investigación, que se regirá por lo previsto en el artículo 67 de esta ley orgánica.

El procedimiento tendrá una duración máxima de doce meses a contar desde la fecha del acuerdo de inicio. Transcurrido ese plazo se producirá su caducidad y, en consecuencia, el archivo de actuaciones.

En relación con las actuaciones previas de investigación el art. 67 de la LOPDGDD dispone lo siguiente:

Artículo 67. Actuaciones previas de investigación.

1. Antes de la adopción del acuerdo de inicio de procedimiento, y una vez admitida a trámite la reclamación si la hubiese, la Agencia Española de Protección de Datos podrá llevar a cabo actuaciones previas de investigación a fin de lograr una mejor determinación de los hechos y las circunstancias que justifican la tramitación del procedimiento.

La Agencia Española de Protección de Datos actuará en todo caso cuando sea precisa la investigación de tratamientos que implique un tráfico masivo de datos personales.

2. Las actuaciones previas de investigación se someterán a lo dispuesto en la sección 2.ª del capítulo I del título VII de esta ley orgánica y no podrán tener una duración superior a dieciocho meses a contar desde la fecha del acuerdo de admisión a trámite o de la fecha del acuerdo por el que se decida su iniciación cuando la Agencia Española de Protección de Datos actúe por propia iniciativa.

De dicha normativa no se infiere en modo alguno que la AEPD tenga que justificar de la manera que se exige el inicio de actuaciones previas. Las actuaciones previas de investigación se realizan para esclarecer los hechos y las circunstancias de lo acontecido, recabando más información al objeto de poder determinar la existencia o no de una posible infracción de la normativa en materia de protección de datos.

En este sentido, el inicio de investigaciones previas y su realización, potestad de la AEPD con o sin reclamaciones, no prejuzga nada, sino que permite recabar la información necesaria para determinar si hay indicios o no de infracción. Incluso tras dicha investigación, puede ser que se archiven las actuaciones por entender, a la vista de la información recabada, que no concurren los elementos necesarios para la

apertura de un procedimiento sancionador. Lo cual, en el presente caso, no ha sucedido.

Lo que sí indica la normativa es que, tras la presentación de reclamaciones, esta Agencia debe decidir si las admite a trámite o no, habiendo decidido finalmente su admisión. Y, como indica el artículo 67.2 LOPDGDD referenciado, la AEPD puede llevar a cabo actuaciones previas de investigación. Lo que aconteció en este caso, a fin de lograr una mejor determinación de los hechos y las circunstancias. Es una potestad que tiene atribuida a la AEPD por el RGPD y por la LOPDGDD.

Asimismo, y a mayor abundamiento, incluso en el supuesto de no haber existido las reclamaciones, el escrito cuestionado no hubiera sido tampoco óbice ni obstáculo para el ejercicio de las potestades de investigación que tiene la AEPD de conformidad con el citado artículo 64.2 que determina que *“Admitida a trámite la reclamación, así como en los supuestos en que la Agencia Española de Protección de Datos actúe por propia iniciativa, con carácter previo al acuerdo de inicio, podrá existir una fase de actuaciones previas de investigación.”*

Por tanto, el presente procedimiento sancionador no se ha iniciado por el contenido o por alguna información nueva aportada en las dos reclamaciones presentadas en esta AEPD, sino por la información y documentación obtenida tras el período de actuaciones previas de investigación, al inferirse de la misma, posibles vulneraciones a la normativa en materia de protección de datos.

A este respecto, se recuerda de nuevo que dichas reclamaciones, sólo se admiten siendo la documentación y todo lo recopilado durante dichas actuaciones de investigación lo que ha motivado, exclusivamente, el inicio del presente procedimiento sancionador, y no las citadas reclamaciones.

- ORANGE BANK es víctima de un delito.

Frente a ello, debe señalarse que la culpabilidad de la parte actora no puede considerarse excluida ni atenuada por el hecho de que haya mediado la actuación fraudulenta de un tercero, pues la responsabilidad de la parte actora no deriva de la actuación de éste, sino de la suya propia.

En ningún caso se ha exigido una infalibilidad total de las medidas que se pueden adoptar para garantizar una protección adecuada en el tratamiento de los datos personales. (...)

(...)

(...)

ORANGE BANK es responsable del tratamiento de estos datos y en consecuencia responsable de que los datos tratados por su cuenta tengan las debidas garantías de seguridad que impidan o dificulten una pérdida de confidencialidad, integridad o disponibilidad de los datos, lo que no sucedió en este caso al encontrarse los datos sin cifrar.

- Ausencia de una conducta culpable o negligente de ORANGE BANK.

En cuanto a que la práctica totalidad de expedientes incoados por esta Agencia en relación con brechas de seguridad derivadas de un ciberataque con ransomware han resultado archivados, se significa que, además de poner de manifiesto que este tipo de ataques están a la orden del día y por tanto son previsibles en gran medida, cada ataque es diferente pues, incluso aunque el ataque fuese similar, en cada una las empresas que lo sufren, son distintas, con tratamientos de datos personales diferentes y particulares y en cada caso hay que analizar las medidas de seguridad existentes (si existían, si eran adecuadas para garantizar un nivel de seguridad apropiado al riesgo concreto en cada caso, si fueron eficientes, si se observaron, etc.).

En materia de protección de datos las medidas técnicas y organizativas a adoptar por los responsables del tratamiento y demás obligaciones a cumplir exigidas por el RGPD, deben ser las adecuadas en relación con los concretos riesgos que suponen los específicos tratamientos que realice cada responsable. Por tanto, al analizar la diligencia de unos y otros en el cumplimiento de la normativa, ha de estarse a las circunstancias de cada caso concreto, teniendo en cuenta la naturaleza, el alcance, el contexto y los fines de cada tratamiento, no existiendo, por tanto, casos idénticos.

La jurisprudencia es clara respecto a esto. Así, la Sentencia de la Audiencia Nacional de 28 de abril de 2023 (SAN 28.04.2023 REC. 409/2021 indica que *“Se alude a un trato sancionador discriminatorio puesto que esa multa o sanción económica puede sustituirse por las medidas del art. 58 RGPD, medidas menos gravosas como podría ser el apercibimiento. Y hace referencia a otras infracciones cometidas por otras entidades. Por supuesto la actora trata de comparar esta situación con otro procedimiento sancionador que se menciona, pero no estamos ante un trato discriminatorio o que se vulnere el principio de igualdad puesto que es un principio que solo opera en el marco de la legalidad cuando situaciones de hecho iguales tienen un tratamiento diferente sin justificación razonable. Como señala la STS de 20 de enero 2004, “la igualdad ha de predicarse dentro de la legalidad, de modo que si la actuación correcta de la Administración es la ahora enjuiciada, según hemos declarado, la invocada como contraria a ella no lo fue y, por consiguiente, no cabe esgrimirla para pedir que se le aplique al recurrente un trato igual, ya que, como esta Sala del Tribunal Supremo ha declarado en sus sentencias de 16 de junio de 2003 , 14 de julio de 2003 y 20 de octubre de 2003 que «el principio de igualdad carece de trascendencia para amparar una situación contraria al ordenamiento jurídico», y ello, como indica la propia Sala sentenciadora, al margen de no haberse acreditado la actuación administrativa aducida como contradictoria con la presente”.*

- (...)

A este respecto, se significa que la vulneración de la confidencialidad que se imputa a es la que le corresponde, es decir, por incumplir la obligación impuesta en el artículo 5.1.f) de tratar los datos de tal manera que se garantice una seguridad adecuada de los mismos, incluida la protección contra el tratamiento no autorizado o ilícito, mediante la aplicación de medidas técnicas u organizativas apropiadas. La pérdida de control sobre los propios datos personales se produce desde el momento en que se materializa la brecha de datos personales, es decir, desde que se produce ese acceso

por parte de un tercero no autorizado a los datos personales. Esta es la pérdida de confidencialidad que se le imputa.

Existen medidas dirigidas específicamente a garantizar la confidencialidad de los datos personales, (...).

A este respecto, procede traer a colación la Sentencia de 22 de junio de 2021- Rec. 1210/2018, y la Sentencia de 5 de noviembre de 2011 -Rec. 1796/2019 en la cual la Sala valorando el elemento subjetivo o culpabilístico *“...insistiendo en que la culpabilidad de la parte actora no puede considerarse excluida ni atenuada por el hecho de que haya mediado la posible actuación fraudulenta de un tercero, pues la responsabilidad de la parte actora no deriva de la actuación de éste, sino de la suya propia”*.

- Inadmisibilidad de la responsabilidad objetiva y diligencia y adecuación de las medidas adoptadas e implementadas por ORANGE BANK

Debe señalarse que en ningún caso se ha exigido una infalibilidad total de las medidas que se pueden adoptar para garantizar una protección adecuada en el tratamiento de los datos personales. Sin embargo, una vez producido el ataque, debe evaluarse la diligencia de responsables y encargados en la aplicación de las medidas técnicas y organizativas apropiadas para garantizar un nivel de seguridad adecuado al riesgo, teniéndose en cuenta el estado de la técnica, los costes de aplicación, la naturaleza, el alcance, el contexto y los fines del tratamiento. En el presente caso, la pérdida de confidencialidad se constató consecuencia de la exfiltración de los datos.

A este respecto, procede señalar que ni el art. 5.1,f) ni el artículo 32 del RGPD se refieren únicamente a medidas de seguridad de la información o de ciberseguridad dirigidas a evitar ataques informáticos, sino a la obligación de aplicar medidas técnicas y organizativas apropiadas para garantizar un nivel de seguridad adecuado al riesgo que incluya, entre otros, la capacidad de garantizar la confidencialidad, integridad, disponibilidad y resiliencia permanentes de los sistemas y servicios del tratamiento y la capacidad de restaurar la disponibilidad y el acceso a los datos personales de forma rápida en caso de incidente físico o técnico. Y todo ello teniendo en cuenta el estado de la técnica, los costes de aplicación y la naturaleza, el contexto y los fines del tratamiento, así como los riesgos de probabilidad y gravedad variables para los derechos y libertades de las personas físicas.

Asimismo, el apartado segundo del citado artículo 32 indica que al evaluar la adecuación del nivel de seguridad se tendrán particularmente en cuenta los riesgos que presente el tratamiento de datos en particular como consecuencia de la destrucción, pérdida o alteración accidental o ilícita de datos personales transmitidos, conservados o tratados de otra forma, o la comunicación o accesos no autorizados.

Es decir, el RGPD establece la obligación de que se traten los datos personales de tal forma que se garantice la confidencialidad, integridad y disponibilidad de estos y, para ello, resulta necesario evaluar los riesgos y, en función de ellos, adoptar las medidas adecuadas para evitarlos o mitigar su impacto sobre los derechos y libertades de las personas físicas.

En el presente caso, como se ha señalado anteriormente, MARKTEL sufrió un ataque con ransomware, causando una brecha de seguridad consistente en una brecha de confidencialidad y disponibilidad, al constatarse un acceso indebido a los datos personales tratados que fueron cifrados por el atacante.

Por tanto, considerando que los ataques son previsibles (y no todos inevitables), debe disponerse de mecanismos que permitan garantizar la confidencialidad de los datos. Por ello, debe partirse de la conciencia de que los mecanismos de prevención difícilmente garantizan totalmente la seguridad de los datos ante determinados ataques sofisticados y, en consecuencia, deben basarse en la valoración de medidas que puedan mitigar el impacto y permitir una adecuada respuesta en caso de materialización del riesgo.

Como ya se ha indicado anteriormente existen medidas dirigidas específicamente a garantizar la confidencialidad de los datos personales, (...).

- Responsabilidad del encargado del tratamiento.

En relación con la responsabilidad de los datos personales filtrados, ha quedado constatado que MARKTEL actuaba como subencargado de tratamiento al prestar el servicio de recobro de impagos de clientes de ORANGE BANK que adquirirían deudas por la compra de terminales a plazos. ORANGE ESPAGNE actuaba con un doble rol con respecto a estos datos, por un lado, como responsable del tratamiento de los datos personales facilitados en la compra, y por otro como encargado de tratamiento de ORANGE BANK SA al existir una cesión de derechos de créditos de las deudas contraídas en la venta a plazos del terminal, encargando a ORANGE ESPAGNE SAU la gestión de las operaciones de recobro en caso de impago.

Por tanto, ORANGE BANK SA es el responsable de los derechos de crédito de la deuda contraída y de sus datos personales. Y ello con independencia de la actuación y la responsabilidad en la que hayan podido incurrir terceros, pues la negligencia o actuación ilegal de terceros no excluye la suya propia.

- Falta de proporcionalidad de la sanción propuesta.

Hay que señalar que el artículo 83.1 del RGPD previene que *“Cada autoridad de control garantizará que la imposición de las multas administrativas con arreglo al presente artículo por las infracciones del presente Reglamento indicadas en los apartados 4, 5 y 6 sean en cada caso individual efectivas, proporcionadas y disuasoria”*.

Las multas por tanto según se deduce del precepto invocado han de ser efectivas, proporcionadas y disuasorias para la consecución de la finalidad pretendida por el RGPD.

Es cierto, que para que dicho sistema funcione con todas sus garantías es necesario que varios elementos se desplieguen de forma íntegra y completa. La aplicación de reglas ajenas al RGPD respecto de la determinación de las multas en cada uno de los Estados miembros aplicando su derecho nacional, ya sea por circunstancias agravantes o atenuantes no previstas en el RGPD -o en la LOPDGDD en el caso español al permitirlo el propio RGPD-, restaría efectividad al sistema perdiendo su

sentido, su finalidad teleológica, la voluntad del legislador, resultando que las multas impuestas por distintas infracciones dejarían de ser efectivas, proporcionadas y disuasorias. Y de esta forma también se hurtaría a los interesados de la garantía efectiva de sus derechos y libertades, debilitando la aplicación uniforme del RGPD. Se disminuirían los mecanismos de protección de los derechos y las libertades de los ciudadanos y sería contrario con el espíritu del RGPD.

El RGPD está dotado de su propio principio de proporcionalidad que ha de ser aplicado en sus estrictos términos.

En cuanto al principio de proporcionalidad de las sanciones, la Audiencia Nacional en numerosas sentencias ha señalado que el principio de proporcionalidad no puede sustraerse al control jurisdiccional, pues el margen de apreciación que se otorga a la Administración en la imposición de sanciones dentro de los límites legalmente previstos, debe ser desarrollado ponderando en todo caso, las circunstancias concurrentes, al objeto de alcanzar la necesaria y debida proporción entre los hechos imputados y la responsabilidad exigida, dado que toda sanción, debe determinarse en congruencia con la entidad de la infracción cometida y según un criterio de proporcionalidad en relación con las circunstancias del hecho. De modo que la proporcionalidad constituye un principio normativo que se impone a la Administración y que reduce el ámbito de sus potestades sancionadoras.

Pues bien, de conformidad con las circunstancias que concurren en el presente caso, las cuales han sido evaluadas meticulosa y convenientemente, la presente resolución no vulnera el principio de proporcionalidad en la determinación de la sanción impuesta, resultando ponderada y proporcionada a la gravedad de la infracción cometida, la importancia de los hechos, así como las circunstancias tenidas en cuenta para graduar la sanción, sin que se aprecien razones que justifiquen aún más la minoración efectuada, sobre todo teniendo en cuenta la cuantía a la que pueden ascender dichas sanciones de conformidad con el art. 83.5 del RGPD, que prevé para la infracción del artículo 5.1.f) del RGPD, *“con multas administrativas de 20.000.000€ como máximo o, tratándose de una empresa, de una cuantía equivalente al 4% como máximo del volumen de negocio total anual global del ejercicio financiero anterior, optándose por la de mayor cuantía”*.

- La naturaleza, gravedad y duración de la infracción (Artículo 83.2 a) del RGPD).

A este respecto, procede señalar que no procede admitir tales consideraciones como atenuante o como circunstancia que disminuya la gravedad de los hechos, más bien al contrario, pues precisamente por el elevado número de tratamientos que realiza y clientes que han resultado afectados, la entidad investigada está obligada a actuar con la especial diligencia que debe exigirse a una entidad de estas características, que realiza numerosos tratamientos de datos personales. No puede obviarse el número considerable de afectados de la brecha de datos personales.

(...).

Procede recordar la Sentencia de la Audiencia Nacional de 17/10/2007 (rec. 63/2006), que respecto de entidades cuya actividad lleva aparejado el continuo tratamiento de datos de clientes, indica *“...el Tribunal Supremo viene entendiendo que existe imprudencia siempre que se desatiende un deber legal de cuidado, es decir, cuando el*

infractor no se comporta con la diligencia exigible. Y en la valoración del grado de diligencia ha de ponderarse especialmente la profesionalidad o no del sujeto, y no cabe duda de que, en el caso ahora examinado, cuando la actividad de la recurrente es de constante y abundante manejo de datos de carácter personal ha de insistirse en el rigor y el exquisito cuidado por ajustarse a las previsiones legales al respecto.”

En el caso que nos ocupa, el tipo de datos que trata y que fueron afectados por la brecha y que ORANGE BANK parece desdeñar, supone un riesgo alto, en caso de vulnerarse su confidencialidad, de ser usados de modo fraudulento: suplantación de la identidad phishing, fraude financiero, etc.

Lo que se trata de poner en evidencia es que la infracción del artículo 5.1.f) afecta a uno de los principios básicos en los que se basa la normativa en materia de protección de datos de carácter personal, la confidencialidad, y esa vulneración se halla acrecentada y agravada por el número de afectados por el incidente, los daños y perjuicios provocados (pérdida irreversible de poder y control de los datos personales por los clientes).

– Intencionalidad o negligencia en la infracción (artículo 83.2b) del RGPD).

El hecho de que ORANGE BANK sea una empresa para cuya actividad realiza un constante y abundante manejo de datos personales, realizando tratamientos que implican un probable alto riesgo para los derechos y libertades de las personas físicas supone la exigencia de una diligencia mayor en el tratamiento de los datos personales que la que se pueda exigir a una pequeña empresa que realice tratamientos esporádicos o accesorios.

Teniendo en cuenta que en la conducta de la entidad investigada concurre el elemento de culpabilidad, que es indispensable para poder exigir responsabilidad sancionadora, en este caso se concreta, además, en una muy grave falta de diligencia en el cumplimiento del principio de confidencialidad de los datos de carácter personal como se ha puesto de manifiesto a lo largo del procedimiento.

(...)

– La vinculación entre la actividad empresarial de la reclamada y el tratamiento de datos personales de clientes o de terceros (artículo 83.2.k, del RGPD en relación con el artículo 76.2.b, de la LOPDGDD).

La agravante prevista en el art. 76.2.b) de la LOPDGDD opera cuando se vincule la actividad el infractor con la realización de tratamientos de datos personales y, es obvio que, en relación con el presente responsable del tratamiento, su actividad, en este concreto caso bancaria, está claramente vinculada, de manera directa, con múltiples tratamientos de datos personales que afectan a miles de clientes.

En este sentido, la Audiencia Nacional ha considerado que es correcto apreciar la agravante prevista en el art. 76.2.b) de la LOPDGDD siempre que exista la vinculación antedicha y así lo ha considerado en numerosas sentencias, entre otras la fecha 04/07/2024, (rec. 382/2022) señala con relación a la citada circunstancia que:

“Como también, cabe apreciar la agravante del carácter continuado de la infracción, recogida en el art. 76.2.a) de la Ley Orgánica 3/2018, de 5 de diciembre, de

Protección de Datos Personales y garantía de los derechos digitales, remitiéndonos para ello cuando analizamos la aplicación del RGPD a la infracción que nos ocupa.

Como igualmente, la apreciación de la vinculación de la actividad del infractor con la realización de tratamientos de datos personales (art. 72.2.b) la Ley Orgánica 3/2018, de 5 de diciembre), debido a que la actividad de la parte recurrente está vinculada con el tratamiento de datos tanto de clientes como de terceros; es conocida la citada vinculación ya que la entidad por su actividad está en permanente contacto con clientes y terceros tratando un gran volumen de datos, lo que le impone un mayor deber de diligencia” (el subrayado es nuestro).

- Circunstancias atenuantes

A este respecto, procede señalar, en primer lugar, que los requerimientos de la AEPD son de obligado cumplimiento.

Por tanto, en este caso, el grado de cooperación con la Agencia no puede ser apreciado y no procede aplicar la atenuante, por cuanto la consideración de la cooperación con la Agencia como atenuante, tal y como pretende la entidad, no está ligada a ninguno de los supuestos en los que se encuentre prevista legalmente una colaboración o cooperación o dar respuesta a un requerimiento por mor de un mandato legal. Por tanto, cuando las actuaciones son debidas y obligadas por la Ley, como en el caso que nos ocupa, no procede su aplicación.

En el presente caso, se han tenido en cuenta las circunstancias del caso: la gravedad de la infracción, las consecuencias de la misma, la falta de diligencia mostrada, los concretos tratamientos que realiza, la tipología de datos personales y el número de personas afectadas, las circunstancias de la empresa (tamaño, volumen de negocio, etc.), circunstancias todas ellas puestas de manifiesto y motivadas en el Acuerdo de Inicio del presente procedimiento sancionador y que se reproducen en la presente propuesta, las cuales permiten concluir que se ha respetado el principio de proporcionalidad a la hora de determinar la cuantía de la multa finalmente impuesta.

En consecuencia, las alegaciones deben ser desestimadas, significándose que las argumentaciones presentadas no desvirtúan el contenido esencial de las infracciones que se declaran cometidas ni suponen causa de justificación o exculpación suficiente.

IV Respuesta a las alegaciones a la Propuesta de Resolución

En relación con las alegaciones aducidas a la Propuesta de Resolución del presente procedimiento sancionador, se procede a dar respuesta a las mismas, según el orden expuesto:

1. Argumentos nuevos de la propuesta de resolución.

En relación con las manifestaciones efectuadas por Orange Bank S.A. Sucursal en España, que reproducen las alegaciones formuladas a lo largo del procedimiento sancionador, debe señalarse que ya fueron analizadas pormenorizadamente y desestimadas en los Fundamentos de Derecho de la Propuesta de Resolución, que aparece transcrita en el Fundamento de Derecho III de la presente Resolución, a la que, en aras de economía procesal, procede remitirse.

2. En relación con los hechos.

2.1 Número de datos afectados por la brecha de seguridad.

A este respecto, procede aclarar que del mismo incidente (ciberataque), no sólo se vieron afectados datos personales de Orange Bank S.A. Sucursal en España, sino que, al acceder a los sistemas de MARKTEL, se vieron afectados datos de otras empresas.

(...):

• (...)

(...)

En este sentido, se aclara que la afectación de datos personales de clientes ajenos a Orange Bank S.A. Sucursal en España no forma parte de este procedimiento sancionador, dirigido exclusivamente a examinar la conducta de Orange Bank S.A. Sucursal en España, por cuanto no es responsable ni de los datos personales de clientes afectados que pertenecen a otras empresas, ni de la posible falta de adopción de las medidas adecuadas para su protección.

Por tanto, se insiste en que se ha analizado de forma independiente la gestión que realiza Orange Bank S.A. Sucursal en España, sin que pueda responder por posibles incumplimientos de la normativa de protección de datos en que hayan podido incurrir otras empresas.

El hecho de que se haya hecho constar el número total de registros afectados por el ciberataque, en nada afecta a su responsabilidad ni le produce indefensión, por cuanto en todo momento conoce los hechos que se le imputan, la infracción que los mismos suponen, su tipificación, la responsabilidad en que ha incurrido, así como que ha tenido y tiene la oportunidad de formular alegaciones y presentar cuanta documentación considere oportuna en defensa de sus intereses que le permite la legislación aplicable.

2.2 Número de datos declarados por Orange Bank S.A. Sucursal en España.

A este respecto, procede señalar que la notificación a las autoridades de control de la violación de la seguridad de los datos personales es una obligación impuesta al responsable del tratamiento por el RGPD (artículo 33), es decir, su observancia viene impuesta por imperativo legal, se trata de un mandato que ha de ser cumplido, por lo que su incumplimiento por el responsable, de conformidad con lo requerido en dicho precepto, puede suponer una infracción del RGPD.

Por tanto, el cumplimiento de la obligación impuesta al responsable no puede ser apreciado para atenuar la responsabilidad que se imputa a Orange Bank S.A. Sucursal en España, por cuanto es una actuación debida y obligada por la Ley.

2.3 Números IBAN sin ofuscar.

(...)

(...)

A este respecto, procede señalar que la circunstancia alegada tampoco puede ser considerada como atenuante o como circunstancia que disminuya la gravedad de los hechos, pues nunca se la ha considerado responsable de la totalidad de los datos publicados, y precisamente por el elevado número de tratamientos que realiza y clientes que han resultado afectados, Orange Bank S.A. Sucursal en España está obligada a actuar con la especial diligencia que debe exigirse a una entidad de estas características, que realiza numerosos tratamientos de datos personales.

Procede recordar la Sentencia de la Audiencia Nacional de 17/10/2007 (rec. 63/2006), que respecto de entidades cuya actividad lleva aparejado el continuo tratamiento de datos de clientes, indica “...el Tribunal Supremo viene entendiendo que existe imprudencia siempre que se desatiende un deber legal de cuidado, es decir, cuando el infractor no se comporta con la diligencia exigible. Y en la valoración del grado de diligencia ha de ponderarse especialmente la profesionalidad o no del sujeto, y no cabe duda de que, en el caso ahora examinado, cuando la actividad de la recurrente es de constante y abundante manejo de datos de carácter personal ha de insistirse en el rigor y el exquisito cuidado por ajustarse a las previsiones legales al respecto.”

En el caso que nos ocupa, el tipo de datos que trata y que fueron afectados por la brecha y que Orange Bank S.A. Sucursal en España parece desdeñar, supone un riesgo alto, en caso de vulnerarse su confidencialidad, de ser usados de modo fraudulento: suplantación de la identidad, phishing, fraude financiero, etc.

3. Sobre la incompetencia de la Agencia Española de Protección de Datos.

A este respecto, procede señalar que esta manifestación sobre la incompetencia de la Agencia Española de Protección de Datos ya fue esgrimida frente al Acuerdo de Inicio y respondida por esta Agencia en la Propuesta de resolución, a la cual procede remitirse.

En dicha Propuesta se aclaró su condición de responsable del tratamiento de los datos que realiza en España. Esta Agencia considera la responsabilidad directa de ORANGE BANK SA SUCURSAL EN ESPAÑA en los hechos y en los que la AEPD es competente para sancionar.

Como ya se indicó, la entidad tiene prerrogativas suficientes como para decidir sobre los fines y los medios de los tratamientos realizados en España de sus clientes y, por tanto, dichos tratamientos se encuentran dentro del ámbito competencial de la Agencia Española Protección de Datos.

Para que un tratamiento sea transfronterizo será necesario que se cumpla alguna de las condiciones expresadas en el artículo 4.23 del RGPD:

- El tratamiento de datos personales se lleve a cabo en el contexto de las actividades de establecimientos en más de un Estado miembro de un responsable o

encargado del tratamiento en la Unión cuando el responsable o encargado del tratamiento esté establecido en más de un Estado miembro; o

- El tratamiento de datos personales se lleve a cabo en el contexto de las actividades de un único establecimiento de un responsable o encargado del tratamiento en la Unión, pero que afecte sustancialmente o es probable que afecte sustancialmente a los interesados en más de un Estado miembro.

En este caso, el tratamiento se lleva a cabo exclusivamente por cuenta de ORANGE BANK sucursal en España, que fue quien contrató con ORANGE ESPAGNE y esta a su vez con MARKEL, y se realiza exclusivamente respecto de interesados en España. Por tanto, no concurre ninguna de las condiciones que permiten considerar un tratamiento transfronterizo.

En el supuesto que se examina, nos encontramos ante un tratamiento nacional de competencia exclusiva de la Agencia Española de Protección de Datos y debe por tanto tratarse conforme determina el art. 55 del RGPD. El tratamiento se lleva a cabo en el contexto de actividades de ORANGE BANK, con establecimiento en España y sólo afecta a interesados en España, por consiguiente, la Agencia Española de Protección de Datos es plenamente competente para tramitar el presente procedimiento sancionador.

4. Sobre la caducidad de las actuaciones previas.

Como ya se expuso, las reclamaciones de las que trae causa el presente procedimiento se presentaron, en fechas 18 de noviembre y 9 de diciembre de 2022, y fueron admitidas a trámite, los días 18 y 28 de febrero de 2023, dentro del plazo de tres meses fijado en el art. 65.5 de la LOPDGDD. El presente procedimiento se inició el 16 de febrero de 2024, antes por tanto del transcurso del plazo de 12 meses, a contar desde la fecha del acuerdo de admisión a trámite, fijado por el art. 67.2 de la LOPDGDD para la caducidad de las actuaciones de investigación, en la redacción vigente.

Así disponía el artículo 6.5. LOPDGDD que:

“5. La decisión sobre la admisión o inadmisión a trámite, así como la que determine, en su caso, la remisión de la reclamación a la autoridad de control principal que se estime competente deberá notificarse al reclamante en el plazo de tres meses. Si transcurrido este plazo no se produjera dicha notificación, se entenderá que prosigue la tramitación de la reclamación con arreglo a lo dispuesto en este Título a partir de la fecha en que se cumplieren tres meses desde que la reclamación tuvo entrada en la Agencia Española de Protección de Datos.”

En relación con las actuaciones previas de investigación, el art. 67 de la LOPDGDD establecía lo siguiente:

Artículo 67. Actuaciones previas de investigación.

1. Antes de la adopción del acuerdo de inicio de procedimiento, y una vez admitida a trámite la reclamación si la hubiese, la Agencia Española de Protección de Datos

podrá llevar a cabo actuaciones previas de investigación a fin de lograr una mejor determinación de los hechos y las circunstancias que justifican la tramitación del procedimiento.

La Agencia Española de Protección de Datos actuará en todo caso cuando sea precisa la investigación de tratamientos que implique un tráfico masivo de datos personales.

2. Las actuaciones previas de investigación se someterán a lo dispuesto en la Sección 2.^a del Capítulo I del Título VII de esta ley orgánica y no podrán tener una duración superior a doce meses a contar desde la fecha del acuerdo de admisión a trámite o de la fecha del acuerdo por el que se decida su iniciación cuando la Agencia Española de Protección de Datos actúe por propia iniciativa o como consecuencia de la comunicación que le hubiera sido remitida por la autoridad de control de otro Estado miembro de la Unión Europea, conforme al artículo 64.3 de esta ley orgánica. (el subrayado es nuestro)

Por lo que el planteamiento que la entidad investigada realiza sobre esta cuestión en sus alegaciones no se ajusta a Derecho.

5. Sobre la contradicción entre el acuerdo de inicio del expediente y el archivo de actuaciones de 28 de diciembre de 2022.

En la propuesta de resolución también se respondió y argumentó sobre la errónea interpretación que Orange Bank S.A. Sucursal en España hacía sobre el contenido y la naturaleza del escrito de la DIT que en ningún caso puede ser considerado una decisión de archivo de actuaciones.

Pues bien, el citado escrito no tiene el carácter decisorio y resolutorio que pretende, ni por su contenido, ni por su forma y ello no es óbice ni puede impedir en modo alguno la potestad de investigación que tiene la AEPD y su ejercicio a través de las funciones de inspección e investigación que la Subdirección General de Inspección de Datos tiene encomendadas. Sobre todo, tras la presentación de reclamaciones por parte de personas afectadas y que la LOPDGDD obliga a su tramitación.

Hemos de indicar que la AEPD tiene atribuidas, en virtud de los artículos 57 y 58 del RGPD, funciones de investigación, en la medida oportuna, respecto de las reclamaciones presentadas al efecto.

En el supuesto ahora examinado, la AEPD, tras la realización de las investigaciones oportunas y en relación con una serie de hechos concretos que considera probados, incardina los mismos en el tipo infractor que considera adecuado, conforme a la aplicación e interpretación de la normativa, motivando de manera prolija y suficiente tal actuación. Y es que la AEPD, al igual que el resto de los poderes públicos, está vinculada al principio de legalidad (artículo 9.1 y 9.3 Constitución -CE-) que implica la aplicación e interpretación de las normas atendiendo al supuesto de hecho específico que concurra en cada caso.

La AEPD ha motivado con sucinta referencia de hecho y fundamentos de derecho, conforme exige el artículo 35.1.h) de la LPACAP, el fundamento de su decisión.

Asimismo, ha garantizado los derechos previstos en los artículos 64.2.f) y 89.2 de la LPACAP, entre los que se encuentra el derecho a formular alegaciones, sin que, por tanto, pueda aducir indefensión. Ha podido alegar y aportar al procedimiento todo lo que a su derecho ha convenido, sin limitación alguna por parte de la AEPD. Todas las alegaciones formuladas al efecto ya han sido consideradas y contestadas.

Se reitera que el archivo de actuaciones requiere una resolución que de modo expreso y motivado archive las actuaciones de investigación iniciadas conforme al art. 67 de la LOPDGDD, lo que no ha sucedido en este caso.

6. Existe un ánimo persecutorio de la Agencia frente a Orange Bank S.A. Sucursal en España.

A este respecto, efectuar varios matices.

En primer término, el ejercicio de la potestad sancionadora se ha llevado a cabo previo procedimiento administrativo, acompañado de las debidas garantías, y ha llevado a determinar los Hechos, probar la culpa y graduar la respuesta administrativa. Esta graduación no se ha hecho al margen de las circunstancias concurrentes, sino que como manifestación y exigencia del principio de transparencia (artículo 3.1.c) LRJSP) y derecho a una buena administración (artículo 41 de la Carta de los Derechos Fundamentales de la UE), los hechos se han tratado de forma imparcial y equitativamente, motivando en todo momento la decisión final.

Por lo tanto, la Agencia se ha limitado a analizar las circunstancias del caso concreto con el fin de identificar la existencia de indicios o evidencias (o no) de infracción en su ámbito competencial. Y consecuencia de ello, ha considerado probado que Orange Bank S.A. Sucursal en España ha vulnerado uno de los principios relativos al tratamiento (artículo 5.1.f) RGPD), por lo que este argumento no puede aceptarse.

7. Tamaño de Orange Bank S.A. Sucursal en España.

En el presente caso, se tienen en cuenta para la imposición de la sanción las circunstancias del caso: la gravedad de la infracción, las consecuencias de esta, la falta de diligencia mostrada, los concretos tratamientos que realiza, la tipología de datos personales y el número de personas afectadas, circunstancias todas ellas puestas de manifiesto y motivadas en la Propuesta de resolución del presente procedimiento sancionador, a la que nos remitimos.

También se tienen en cuenta, en este caso, las alegaciones de ORANGE BANK relativas al tamaño y volumen de negocio de la entidad.

8. Falta de proporcionalidad de la sanción propuesta.

En cuanto al incumplimiento del principio de proporcionalidad, el RGPD prevé expresamente la posibilidad de graduación, mediante la previsión de multas susceptibles de modulación, en atención a una serie de circunstancias de cada caso individual.

Lo cierto es que se ha producido una infracción del artículo 5.1.f) del RGPD que debe ser sancionada con una multa en atención a las graves circunstancias individuales concurrentes. Dicha multa debe reunir las características impuestas por el artículo 83.1 del RGPD, esto es, debe individualizarse y ser efectiva, proporcionada y disuasoria.

La multa administrativa será efectiva porque conducirá a la compañía a aplicar las medidas técnicas y organizativas que garanticen la confidencialidad de los datos sujetos a su tratamiento.

Igualmente, la multa ha de ser disuasoria, a los efectos de que la conducta infractora no se reitere en el futuro. En este sentido debe generar un efecto disuasorio respecto del incumplimiento y vulneración de la normativa de protección de datos y nunca resultar más beneficioso para el infractor que el cumplimiento de la norma infringida.

En cuanto al principio de proporcionalidad de las sanciones, la Audiencia Nacional, en numerosas sentencias, ha señalado que el principio de proporcionalidad no puede sustraerse al control jurisdiccional, pues el margen de apreciación que se otorga a la Administración en la imposición de sanciones dentro de los límites legalmente previstos, debe ser desarrollado ponderando en todo caso, las circunstancias concurrentes, al objeto de alcanzar la necesaria y debida proporción entre los hechos imputados y la responsabilidad exigida, dado que toda sanción, debe determinarse en congruencia con la entidad de la infracción cometida y según un criterio de proporcionalidad en relación con las circunstancias del hecho. De modo que la proporcionalidad constituye un principio normativo que se impone a la Administración y que reduce el ámbito de sus potestades sancionadoras.

Pues bien, teniendo en cuenta la cuantía a la que pueden ascender dichas sanciones de conformidad con el art. 83.5 del RGDP, que prevé para la infracción del artículo 5.1.f) del RGDP, *“con multas administrativas de 20.000.000€ como máximo o, tratándose de una empresa, de una cuantía equivalente al 4% como máximo del volumen de negocio total anual global del ejercicio financiero anterior, optándose por la de mayor cuantía”* y que ORANGE BANK ha acreditado que su volumen de negocios en el año 2022 ascendió a (...) €, este es el importe que se ha de tener en cuenta a la hora de fijar el límite máximo del importe de la multa.

Asimismo, se tienen en cuenta las circunstancias del caso concreto: la gravedad de la infracción, las consecuencias de la misma, la falta de diligencia mostrada, los concretos tratamientos que realiza, la tipología de datos personales y el número de personas afectadas, las circunstancias de la empresa (tamaño, volumen de negocio, etc.), circunstancias todas ellas puestas de manifiesto y motivadas en el Acuerdo de Inicio del presente procedimiento sancionador y que se reproducen en la presente Resolución, a la que nos remitimos, las cuales permiten anticipar que se ha respetado el principio de proporcionalidad a la hora de determinar la cuantía de la multa finalmente impuesta.

9. Calificación de la infracción como muy grave.

Como ha quedado acreditado en la instrucción de este procedimiento, la imposición de la sanción deriva de unos Hechos Probados que constituyen una infracción muy grave del RGPD.

Los hechos se imputan a Orange Bank S.A. Sucursal en España, como responsable del tratamiento, por la violación del principio del artículo 5.1.f) RGPD.

La Agencia considera que la naturaleza de la infracción es muy grave puesto que entraña un riesgo importante para los derechos de los afectados por pérdida irreversible de disposición y control de los datos personales por lo que, debe

rechazarse rotundamente la afirmación relativa a que *“no puede imputarse a Orange Bank S.A. Sucursal en España una falta completa de previsión y responsabilidad en la protección de los datos y, por ello, no puede achacársele la infracción de los principios del artículo 5 del RGPD”*.

Cabe traer a colación la Sentencia 292/2000, de 30 de noviembre, del Tribunal Constitucional, que configura el derecho a la protección de datos como un derecho autónomo e independiente que consiste en un poder de disposición y de control sobre los datos personales que faculta a la persona para decidir cuáles de esos datos proporcionar a un tercero, sea el Estado o un particular, o qué datos puede este tercero recabar, y que también permite al individuo saber quién posee esos datos personales y para qué, pudiendo oponerse a esa posesión o uso.

Así, de acuerdo con el Fundamento Jurídico 6 de la Sentencia del Alto Tribunal:

“6. La función del derecho fundamental a la intimidad del art. 18.1 CE es la de proteger frente a cualquier invasión que pueda realizarse en aquel ámbito de la vida personal y familiar que la persona desea excluir del conocimiento ajeno y de las intromisiones de terceros en contra de su voluntad (por todas STC 144/1999, de 22 de julio, FJ 8). En cambio, el derecho fundamental a la protección de datos persigue garantizar a esa persona un poder de control sobre sus datos personales, sobre su uso y destino, con el propósito de impedir su tráfico ilícito y lesivo para la dignidad y derecho del afectado. En fin, el derecho a la intimidad permite excluir ciertos datos de una persona del conocimiento ajeno, por esta razón, y así lo ha dicho este Tribunal (SSTC 134/1999, de 15 de julio, FJ 5; 144/1999, FJ 8; 98/2000, de 10 de abril, FJ 5; 115/2000, de 10 de mayo, FJ 4), es decir, el poder de resguardar su vida privada de una publicidad no querida. El derecho a la protección de datos garantiza a los individuos un poder de disposición sobre esos datos. Esta garantía impone a los poderes públicos la prohibición de que se conviertan en fuentes de esa información sin las debidas garantías; y también el deber de prevenir los riesgos que puedan derivarse del acceso o divulgación indebidas de dicha información. Pero ese poder de disposición sobre los propios datos personales nada vale si el afectado desconoce qué datos son los que se poseen por terceros, quiénes los poseen, y con qué fin.”

Por tanto, cualquier actuación que suponga privar a la persona de aquellas facultades de disposición y control sobre sus datos personales, constituye un ataque y una vulneración de su derecho fundamental a la protección de datos.

(...)

Disponer de esta medida con anterioridad hubiera evitado con gran probabilidad el acceso a dichos datos, lo que supone que el riesgo de la pérdida de confidencialidad se ha materializado, conllevando una pérdida total y absoluta de control sobre los mismos. Ello demuestra una falta de diligencia por parte de Orange Bank S.A. Sucursal en España a la hora de implementar las medidas técnicas apropiadas para garantizar un nivel de seguridad adecuado al riesgo para los derechos y libertades de las personas.

El hecho de que Orange Bank S.A. Sucursal en España sea una empresa para cuya actividad financiera realiza un constante y abundante manejo de datos personales, realizando tratamientos que implican un probable alto riesgo para los derechos y

libertades de las personas físicas, supone la exigencia de una diligencia mayor en el tratamiento de los datos personales que la que se pueda exigir respecto de actividades de tratamiento que no conlleven el constante manejo de datos.

10. Necesidad de que la propuesta de resolución se adecúe a las circunstancias de hecho que se han corregido o matizado.

A este respecto, procede señalar que se tiene en cuenta la alegación de Orange Bank respecto del volumen de negocios real de la entidad.

Si bien, este Organismo debe dejar constancia que, en la graduación de la sanción y dada la especialidad de la materia, se tienen en cuenta los criterios por imperativo del artículo 83.2 del RGPD y del apartado 2 del artículo 76 “Sanciones y medidas correctivas” de la LOPDGDD.

V Integridad y confidencialidad

El artículo 5.1.f) “Principios relativos al tratamiento” del RGPD establece:

*“1. Los datos personales serán:
(...)”*

f) tratados de tal manera que se garantice una seguridad adecuada de los datos personales, incluida la protección contra el tratamiento no autorizado o ilícito y contra su pérdida, destrucción o daño accidental, mediante la aplicación de medidas técnicas u organizativas apropiadas («integridad y confidencialidad»).”

En ese mismo sentido, el Considerado 39 RGPD dispone que: “Los datos personales deben tratarse de un modo que garantice una seguridad y confidencialidad adecuadas de los datos personales, inclusive para impedir el acceso o uso no autorizados de dichos datos y del equipo utilizado en el tratamiento.”

El principio de integridad y confidencialidad de los datos exige una garantía de seguridad en la aplicación de medidas técnicas u organizativas que eviten la alteración de los datos personales, su pérdida, tratamiento o acceso no autorizado o ilícito. No es posible la existencia de este derecho fundamental si no se garantizan la confidencialidad, la integridad y la disponibilidad de estos.

De ahí que la integridad y la confidencialidad de los datos personales se consideren esenciales para evitar que los interesados sufran efectos negativos. Por ello, deben tratarse de un modo que se garantice una integridad y confidencialidad adecuadas de los datos personales, especialmente para impedir el acceso tratamiento o uso no autorizados de dichos datos.

En definitiva, es el responsable del tratamiento el que tiene la obligación de integrar las garantías necesarias en el tratamiento, con la finalidad de, en virtud del principio de responsabilidad proactiva, cumplir y ser capaz de demostrar el cumplimiento, al mismo tiempo que respeta el derecho fundamental a la protección de datos.

A este respecto, debe recordarse que la confidencialidad de los datos personales se regula en el artículo 5 del RGPD siendo, por tanto, uno de los principios relativos al tratamiento. Los principios relativos al tratamiento son, por un lado, el punto de partida y la cláusula de cierre del ordenamiento jurídico de protección de datos, constituyendo verdaderas reglas informadoras del sistema con una intensa fuerza expansiva; por otro lado, al tener un alto nivel de concreción, son normas de obligado cumplimiento susceptibles de ser infringidas.

Por tanto, el principio de confidencialidad debe informar todos los aspectos, derechos y obligaciones que conlleva el tratamiento de datos personales. Ello es así, porque la vulneración de la confidencialidad conlleva para sus titulares la pérdida de control sobre los mismos, lo que puede suponer graves riesgos para sus derechos y libertades.

El artículo 5.1.f) del RGPD establece una obligación clara de cumplimiento consistente en impedir tratamientos no autorizados o ilícitos implementando medidas de seguridad adecuadas. En consecuencia, los responsables del tratamiento deben estar en disposición de garantizar la confidencialidad de los datos personales para impedir que un tercero acceda a datos que no son de su titularidad, pues precisamente les compete tratar los datos personales conforme al RGPD y LOPDGDD. Por esta razón, es una actividad en donde la diligencia prestada por éstos es fundamental para evitar este tipo de accesos no autorizados.

En el presente caso, se ha vulnerado el principio de confidencialidad pues consta que tras sufrir un ataque informático por ransomware, se produjo un acceso ilegítimo a datos personales, lo que supuso la pérdida de confidencialidad y de control sobre los mismos.

(...):

- (...)
- (...)
- (...)
- (...)
- (...)
- (...)

(...)

(...)

(...)

Esta pérdida de control sobre los propios datos personales, se traduce en una vulneración del derecho fundamental a la protección de datos reconocido en el artículo 18 de la Constitución Española pues tal y como ha indicado el Tribunal Constitucional (Sentencia 292/2000, de 30 de noviembre de 2000) *“el derecho fundamental a la protección de datos persigue garantizar a la persona un poder de control sobre sus datos personales, sobre su uso y destino, con el propósito de impedir su tráfico ilícito y*

lesivo para la dignidad y derecho del afectado (...) El derecho a la protección de datos garantiza a los individuos un poder de disposición sobre esos datos”.

En este mismo sentido, hay que tener presente también que existen medidas dirigidas específicamente a garantizar la confidencialidad de los datos personales, como el cifrado de los mismos o la aplicación sobre ellos de técnicas de pseudonimización o anonimización, medidas que, en caso de haberse aplicado, hubiera, cuando menos, dificultad el acceso por un tercero no autorizado a los datos personales y, en consecuencia, la publicación ulterior de los mismos. Y ello porque la pérdida de confidencialidad se constató consecuencia de la exfiltración de los datos; pérdida de confidencialidad, acceso de un tercero a los datos personales, que no se hubiera producido si estos hubieran estado cifrados o pseudonimizados o anonimizados, pues los delincuentes se hubieran llevado una información ininteligible.

En consecuencia, se considera que los hechos acreditados son constitutivos de una infracción, imputable a la entidad investigada, por vulneración del artículo 5.1.f) del RGPD.

VI Tipificación de la infracción del artículo 5.1.f) del RGPD

La citada infracción del artículo 5.1.f) del RGPD supone la comisión de las infracciones tipificadas en el artículo 83.5 del RGPD que bajo la rúbrica “*Condiciones generales para la imposición de multas administrativas*” dispone:

“Las infracciones de las disposiciones siguientes se sancionarán, de acuerdo con el apartado 2, con multas administrativas de 20 000 000 EUR como máximo o, tratándose de una empresa, de una cuantía equivalente al 4 % como máximo del volumen de negocio total anual global del ejercicio financiero anterior, optándose por la de mayor cuantía:

- a) los principios básicos para el tratamiento, incluidas las condiciones para el consentimiento a tenor de los artículos 5, 6, 7 y 9; (...)”*

A este respecto, la LOPDGDD, en su artículo 71 “Infracciones” establece que “*Constituyen infracciones los actos y conductas a las que se refieren los apartados 4, 5 y 6 del artículo 83 del Reglamento (UE) 2016/679, así como las que resulten contrarias a la presente ley orgánica*”.

A efectos del plazo de prescripción, el artículo 72 “*Infracciones consideradas muy graves*” de la LOPDGDD indica:

“1. En función de lo que establece el artículo 83.5 del Reglamento (UE) 2016/679 se consideran muy graves y prescribirán a los tres años las infracciones que supongan una vulneración sustancial de los artículos mencionados en aquel y, en particular, las siguientes:

- a) El tratamiento de datos personales vulnerando los principios y garantías establecidos en el artículo 5 del Reglamento (UE) 2016/679. (...)”*

VII Sanción

A fin de determinar la multa administrativa a imponer se han de observar las previsiones de los artículos 83.1 y 83.2 del RGPD, preceptos que señalan:

“1. Cada autoridad de control garantizará que la imposición de las multas administrativas con arreglo al presente artículo por las infracciones del presente Reglamento indicadas en los apartados 4, 5 y 6 sean en cada caso individual efectivas, proporcionadas y disuasorias.

2. Las multas administrativas se impondrán, en función de las circunstancias de cada caso individual, a título adicional o sustitutivo de las medidas contempladas en el artículo 58, apartado 2, letras a) a h) y j). Al decidir la imposición de una multa administrativa y su cuantía en cada caso individual se tendrá debidamente en cuenta:

- a) la naturaleza, gravedad y duración de la infracción, teniendo en cuenta la naturaleza, alcance o propósito de la operación de tratamiento de que se trate, así como el número de interesados afectados y el nivel de los daños y perjuicios que hayan sufrido;*
- b) la intencionalidad o negligencia en la infracción;*
- c) cualquier medida tomada por el responsable o encargado del tratamiento para paliar los daños y perjuicios sufridos por los interesados;*
- d) el grado de responsabilidad del responsable o del encargado del tratamiento, habida cuenta de las medidas técnicas u organizativas que hayan aplicado en virtud de los artículos 25 y 32;*
- e) toda infracción anterior cometida por el responsable o el encargado del tratamiento;*
- f) el grado de cooperación con la autoridad de control con el fin de poner remedio a la infracción y mitigar los posibles efectos adversos de la infracción;*
- g) las categorías de los datos de carácter personal afectados por la infracción;*
- h) la forma en que la autoridad de control tuvo conocimiento de la infracción, en particular si el responsable o el encargado notificó la infracción y, en tal caso, en qué medida;*
- i) cuando las medidas indicadas en el artículo 58, apartado 2, hayan sido ordenadas previamente contra el responsable o el encargado de que se trate en relación con el mismo asunto, el cumplimiento de dichas medidas;*
- j) la adhesión a códigos de conducta en virtud del artículo 40 o a mecanismos de certificación aprobados con arreglo al artículo 42,*
- k) cualquier otro factor agravante o atenuante aplicable a las circunstancias del caso, como los beneficios financieros obtenidos o las pérdidas evitadas, directa o indirectamente, a través de la infracción.”*

Por su parte, el artículo 76 “Sanciones y medidas correctivas” de la LOPDGDD dispone:

“1. Las sanciones previstas en los apartados 4, 5 y 6 del artículo 83 del Reglamento (UE) 2016/679 se aplicarán teniendo en cuenta los criterios de graduación establecidos en el apartado 2 del citado artículo.

2. De acuerdo con lo previsto en el artículo 83.2.k) del Reglamento (UE) 2016/679 también podrán tenerse en cuenta:

- a) El carácter continuado de la infracción.*

- b) La vinculación de la actividad del infractor con la realización de tratamientos de datos personales.*
- c) Los beneficios obtenidos como consecuencia de la comisión de la infracción.*
- d) La posibilidad de que la conducta del afectado hubiera podido inducir a la comisión de la infracción.*
- e) La existencia de un proceso de fusión por absorción posterior a la comisión de la infracción, que no puede imputarse a la entidad absorbente.*
- f) La afectación a los derechos de los menores.*
- g) Disponer, cuando no fuere obligatorio, de un delegado de protección de datos.*
- h) El sometimiento por parte del responsable o encargado, con carácter voluntario, a mecanismos de resolución alternativa de conflictos, en aquellos supuestos en los que existan controversias entre aquellos y cualquier interesado.”*

Sanción por la infracción del artículo 5.1.f) del RGPD

De acuerdo con los preceptos transcritos, a efectos de fijar el importe de la sanción por infracción del artículo 5.1 f) del RGPD, procede graduar la multa teniendo en cuenta:

Como agravantes:

- Artículo 83.2.a) RGPD: Naturaleza, gravedad y duración de la infracción.

Se considera que la naturaleza de la infracción es grave puesto que acarrea una pérdida de confidencialidad y, por tanto, de disposición y control irremediable sobre los datos personales.

- Número de interesados afectados: (...)

(...)

- (...):

- (...)
- (...)
- (...)
- (...)
- (...)
- (...)

- Artículo 83.2.b) RGPD. Intencionalidad o negligencia en la infracción:

El Tribunal Supremo viene entendiendo que existe imprudencia siempre que se desatiende un deber legal de cuidado, es decir, cuando el infractor no se comporta con la diligencia exigible. Y en la valoración del grado de diligencia ha de ponderarse especialmente la profesionalidad o no del sujeto, y no cabe duda de que, en el caso ahora examinado, cuando la actividad de la entidad investigada es de constante y abundante manejo de datos de carácter personal, ha de insistirse en el rigor y el

exquisito cuidado por ajustarse a las prevenciones legales al respecto. [Sentencia de la Audiencia Nacional de 17/10/2007 (rec. 63/2006)]. En este caso existió negligencia grave.

Asimismo, se considera que procede graduar la sanción a imponer de acuerdo con los siguientes criterios que establece el apartado 2 del artículo 76 “Sanciones y medidas correctivas” de la LOPDGDD:

Como agravantes:

- Artículo 76.2.b) LOPDGDD. Vinculación de la actividad del infractor con la realización de tratamientos de datos de carácter personal:

Consta conocido que la entidad investigada es una entidad que lleva a cabo el tratamiento de un gran volumen de datos de carácter personal de sus propios clientes, y que son tratados de forma sistemática en el ejercicio de su actividad bancaria que es la que se ha visto afectada por la brecha de datos personales.

En consecuencia y a efectos del cumplimiento de los requisitos legalmente establecidos, el ejercicio de dicha actividad implica necesariamente el conocimiento y aplicación de la normativa vigente en materia de protección de datos personales.

Esta circunstancia determina un mayor grado de exigencia y profesionalidad y, consiguientemente, de responsabilidad de la entidad, en relación con el tratamiento de los datos personales.

Considerando los factores expuestos, toda vez que Orange Bank ha acreditado que su volumen de negocios correspondiente al año 2022 ascendió a (...) € y que las multas han de ser en cada caso individual efectivas, proporcionadas y disuasorias, la valoración que alcanza la cuantía de la multa es de 200.000 euros.

VIII Adopción de medidas

En el texto de la resolución se establecen cuáles han sido las infracciones cometidas y los hechos que han dado lugar a la vulneración de la normativa de protección de datos, de lo que se infiere con claridad cuáles son las medidas a adoptar, sin perjuicio de que el tipo de procedimientos, mecanismos o instrumentos concretos para implementarlas corresponda a la parte sancionada, pues es el responsable del tratamiento quien conoce plenamente su organización y ha de decidir, en base a la responsabilidad proactiva y en enfoque de riesgos, cómo cumplir con el RGPD y la LOPDGDD.

Por tanto, se considera procedente ordenar al responsable que, en el plazo de seis meses, a partir de la firmeza de la resolución con la que finalice el presente procedimiento, adopte las medidas necesarias para garantizar la confidencialidad de los datos sujetos a su tratamiento aplicable y lo comunique a este Organismo.

Se advierte que no atender la orden de adopción de medidas impuestas por este organismo en la resolución sancionadora podrá ser considerado como una infracción administrativa conforme a lo dispuesto en el RGPD, tipificada como infracción en su

artículo 83.5 y 83.6, pudiendo motivar tal conducta la apertura de un ulterior procedimiento administrativo sancionador.

Por lo tanto, de acuerdo con la legislación aplicable y valorados los criterios de graduación de las sanciones cuya existencia ha quedado acreditada, la Presidencia de la Agencia Española de Protección de Datos RESUELVE:

PRIMERO: IMPONER a ORANGE BANK, S.A. SUCURSAL EN ESPAÑA, con NIF W2503011E,

-por la infracción del artículo 5.1.f) del RGPD, tipificada conforme a lo dispuesto en el artículo 83.5 del RGPD, calificada como muy grave a efectos de prescripción, en el artículo 72.1 a) de la LOPDGDD, una multa de 200.000 euros.

SEGUNDO: ORDENAR a ORANGE BANK, S.A. SUCURSAL EN ESPAÑA, con NIF W2503011E, que en virtud del artículo 58.2.d) del RGPD, en el plazo de 6 meses desde que la presente resolución sea firme y ejecutiva, acredite haber procedido a la implantación de las medidas necesarias para garantizar la confidencialidad de los datos sujetos a su tratamiento, así como que informe a esta Agencia, en el mismo plazo, sobre las medidas adoptadas.

TERCERO: NOTIFICAR la presente resolución a ORANGE BANK, S.A. SUCURSAL EN ESPAÑA.

CUARTO: Esta resolución será ejecutiva una vez finalice el plazo para interponer el recurso potestativo de reposición (un mes a contar desde el día siguiente a la notificación de esta resolución) sin que el interesado haya hecho uso de esta facultad.

Se advierte al sancionado que deberá hacer efectiva la sanción impuesta una vez que la presente resolución sea ejecutiva, de conformidad con lo dispuesto en el art. 98.1.b) de la Ley 39/2015, de 1 de octubre, del Procedimiento Administrativo Común de las Administraciones Públicas (en adelante LPACAP), en el plazo de pago voluntario establecido en el art. 68 del Reglamento General de Recaudación, aprobado por Real Decreto 939/2005, de 29 de julio, en relación con el art. 62 de la Ley 58/2003, de 17 de diciembre, mediante su ingreso, indicando el NIF del sancionado y el número de procedimiento que figura en el encabezamiento de este documento, en la cuenta restringida nº **IBAN: ES00-0000-0000-0000-0000-0000 (BIC/Código SWIFT: CAIXESBBXXX)**, abierta a nombre de la Agencia Española de Protección de Datos en la entidad bancaria CAIXABANK, S.A.. En caso contrario, se procederá a su recaudación en período ejecutivo.

Recibida la notificación y una vez ejecutiva, si la fecha de ejecutividad se encuentra entre los días 1 y 15 de cada mes, ambos inclusive, el plazo para efectuar el pago voluntario será hasta el día 20 del mes siguiente o inmediato hábil posterior, y si se encuentra entre los días 16 y último de cada mes, ambos inclusive, el plazo del pago será hasta el 5 del segundo mes siguiente o inmediato hábil posterior.

De conformidad con lo establecido en el artículo 76.4 de la LOPDGDD y dado que el importe de la sanción impuesta es superior a un millón de euros, será objeto de

publicación en el Boletín Oficial del Estado la información que identifique al infractor, la infracción cometida y el importe de la sanción.

De conformidad con lo establecido en el artículo 50 de la LOPDGDD, la presente Resolución se hará pública una vez haya sido notificada a los interesados.

Contra esta resolución, que pone fin a la vía administrativa conforme al art. 48.6 de la LOPDGDD, y de acuerdo con lo establecido en el artículo 123 de la LPACAP, los interesados podrán interponer, potestativamente, recurso de reposición ante la Presidencia de la Agencia Española de Protección de Datos en el plazo de un mes a contar desde el día siguiente a la notificación de esta resolución o directamente recurso contencioso administrativo ante la Sala de lo Contencioso-administrativo de la Audiencia Nacional, con arreglo a lo dispuesto en el artículo 25 y en el apartado 5 de la disposición adicional cuarta de la Ley 29/1998, de 13 de julio, reguladora de la Jurisdicción Contencioso-administrativa, en el plazo de dos meses a contar desde el día siguiente a la notificación de este acto, según lo previsto en el artículo 46.1 de la referida Ley.

Finalmente, se señala que conforme a lo previsto en el art. 90.3 a) de la LPACAP, se podrá suspender cautelarmente la resolución firme en vía administrativa si el interesado manifiesta su intención de interponer recurso contencioso-administrativo. De ser éste el caso, el interesado deberá comunicar formalmente este hecho mediante escrito dirigido a la Agencia Española de Protección de Datos, presentándolo a través del Registro Electrónico de la Agencia [<https://sedeagpd.gob.es/sede-electronica-web/>], o a través de alguno de los restantes registros previstos en el art. 16.4 de la citada Ley 39/2015, de 1 de octubre. También deberá trasladar a la Agencia la documentación que acredite la interposición efectiva del recurso contencioso-administrativo. Si la Agencia no tuviese conocimiento de la interposición del recurso contencioso-administrativo en el plazo de dos meses desde el día siguiente a la notificación de la presente resolución, daría por finalizada la suspensión cautelar.

938-101224

Olga Pérez Sanjuán

La Subdirectora General de Inspección de Datos, de conformidad con el art. 48.2 LOPDGDD, por vacancia del cargo de Presidencia y Adjuntía